Escuela Técnica Superior de Ingeniería
Universidad de Huelva

Fortaleciendo la Seguridad de la Autenticación: Solución Innovadora con FIDO y PrivacyIDEA en Acción

TRABAJO FIN DE GRADO

Grado en Ingeniería Informática

Autor: Antonio José Muriel Gálvez

Director: Iñaki Fernández de Viana y González

31 de mayo de 2024

Resumen

Este Trabajo de Fin de Grado tiene como objetivo principal explorar las bondades de la tecnología FIDO en comparación con otros métodos de autenticación en línea utilizados comúnmente, con el propósito de proponer una solución efectiva para mejorar la seguridad y la experiencia de usuario en la Universidad de Huelva. El estudio se centra en analizar diferentes tipos de tokens disponibles en privacyIDEA, un sistema de gestión de identidad y autenticación de código abierto, para evaluar su eficacia y compararlos con la tecnología FIDO. Se realiza una investigación exhaustiva sobre las ventajas y desventajas de cada método, así como un análisis comparativo detallado en términos de seguridad, usabilidad, implementación, resistencia a ataques y compatibilidad. Los resultados revelan que FIDO ofrece una solución más segura, conveniente y confiable en comparación con las contraseñas tradicionales, métodos basados en SMS o correo electrónico, y otros tipos de tokens. Basándose en estos hallazgos, se propone una solución que aborda de manera efectiva los desafíos de seguridad en línea y mejora la experiencia general del usuario.

Palabras Clave: Autenticación en línea, Tokens, Métodos de autenticación, Gestión de identidad, Estándar, Criptografía asimétrica.

Abstract

The main objective of this Final Degree Project is to explore the benefits of FIDO technology in comparison with other commonly used online authentication methods, with the aim of proposing an effective solution to improve security and user experience at the University of Huelva. The study focuses on analyzing different types of tokens available in privacyIDEA, an open-source identity management and authentication system, to evaluate their effectiveness and compare them with FIDO technology. A thorough investigation is conducted on the advantages and disadvantages of each method, along with a detailed comparative analysis in terms of security, usability, implementation, attack resistance, and compatibility. The results reveal that FIDO offers a more secure, convenient, and reliable solution compared to traditional passwords, SMS or email-based methods, and other types of tokens. Based on these findings, a solution is proposed that effectively addresses online security challenges and improves the overall user experience.

Keywords: Online authentication, Tokens, Authentication methods, Identity management, Standard, Asymmetric cryptography.

Índice general

1. Introducción **7**
1.1. Contexto y Justificación . . . 7
1.1.1. Avances tecnológico, Servicios y Credenciales . . . 7
1.1.2. Introducción al problema de seguridad en la autenticación en línea . . . 8
1.2. Objetivos del TFG . . . 8
1.2.1. Objetivos Generales . . . 9
1.2.2. Objetivos Específicos . . . 9
1.3. Enfoque y Método Seguido . . . 9
1.4. Planificación . . . 10
1.4.1. Planificación de tares y división de tiempo . . . 10
1.4.2. Recursos Necesarios . . . 11
1.5. Evolución de los Métodos de Autenticación . . . 12

2. FIDO 2 **16**
2.1. Introducción FIDO 2 . . . 16
2.1.1. Que es y su Importancia en linea . . . 16
2.1.2. Problemas de seguridad con métodos y contraseñas tradicionales . . . 17
2.2. Componentes FIDO 2 . . . 19
2.2.1. WebAuth y CTAP . . . 19
2.2.2. Funcionamiento en conjunto . . . 20
2.3. Criptografía Subyacente . . . 21
2.3.1. Detalles sobre ECC . . . 22
2.3.2. Detalles sobre HMAC . . . 22
2.4. Tipos de dispositivos Hardware . . . 23
2.4.1. Descripción de todos los dispositivos hardware . . . 23
2.4.2. Comparación de los dispositivos hardware . . . 26
2.5. Comparación con otros métodos de autenticación . . . 28
2.6. Ventajas y Desafíos . . . 29

3. WebAuthn **31**
3.1. Introducción al estándar WebAuthn . . . 31
3.2. Web Authenticación Api . . . 32
3.2.1. Registro . . . 32

3.2.2. Autenticación . . . 33
3.3. Posibles Escenarios WebAuthn . . . 35
3.3.1. WebAuthn como Segundo Factor (2FA) . . . 35
3.3.2. WebAuthn sin envío de contraseñas . . . 35
3.3.3. WebAuthn sin usuarios ni contraseñas . . . 36
3.3.4. Pérdida de Credenciales . . . 36
3.3.5. Anulación Credenciales (Inactividad) . . . 36
3.3.6. Elimina Credenciales de Autenticador . . . 37
3.4. Ventajas y Desventajas . . . 37

4. Fase de Investigación y Análisis **39**
4.1. Análisis de la Arquitectura y Requisitos de SimpleSAMLphp . . . 39
4.1.1. Componentes y Funcionalidades Clave . . . 39
4.1.2. Requisitos para la Implementación de FIDO y PrivacyIDEA . . . 40

5. Fase de Configuración y Despliegue **42**
5.1. Instalación y Configuración de SimpleSAMLphp . . . 42
5.1.1. Pasos Detallados para la Instalación . . . 42
5.1.2. Configuración de Parámetros Esenciales . . . 43
5.2. Integración de PrivacyIDEA y Configuración del Servidor . . . 45
5.2.1. Configuración de PrivacyIDEA en el Entorno de SimpleSAMLphp . . . 45
5.2.2. Ajustes de Seguridad y Personalización . . . 45
5.3. Políticas Para Usuarios . . . 46
5.3.1. Políticas de Administración . . . 46
5.3.2. Políticas de Usuario . . . 47

6. Fase de Pruebas y Evaluación **49**
6.1. Diseño y Definición de Tokens . . . 49
6.2. Diseño y Casos de Uso . . . 51
6.2.1. Diseño . . . 51
6.2.2. Casos de Uso . . . 53
6.3. Ejemplos Prácticos . . . 55
6.3.1. Registro de un Token . . . 55
6.3.2. Autenticación Sin Segundo Factor . . . 58
6.3.3. Autenticación Con Segundo Factor (HOTP) . . . 60
6.3.4. Autenticación Con Segundo Factor (FIDO) . . . 61
6.4. Comparación con Otros Métodos de Autenticación . . . 61
6.4.1. Resultados y Análisis Comparativos . . . 61
6.4.2. Ventajas y Desventajas de la Solución Implementada . . . 63

7. Resultados y Conclusiones **65**
7.1. Análisis de Resultados . . . 65

8. Adaptación del IDP de la Universidad de Huelva al ENS **67**
8.1. Opciones de Adaptación del IDP al ENS 67
8.2. Selección de la Solución y Justificación 68

9. Glosario **69**

Índice de figuras

2.1. Authentication Flow 20
2.2. Comunicación FIDO2 20
2.3. Serie Yubikey 5 23
2.4. YubiKey 5 FIPS Series 24
2.5. YubiKey Bio Series 24
2.6. Serie YubiKey 5 CSPN 25
2.7. Security Key Series 26
2.8. YubiHSM 2 Series 26

3.1. Registration Flow 33
3.2. Authentication Flow 34
3.3. WebAuthn como segundo factor de autenticación (2F) 35
3.4. WebAuthn sin contraseña 36
3.5. WebAuthn sin usuario ni contraseña 36

6.1. Distribución 52
6.2. Diagrama de Flujo 1 54
6.3. Diseño de Flujo 2 y 3 55
6.4. Login 56
6.5. PrivacyIDEA 56
6.6. Menú PrivacyIDEA 57
6.7. Registro de Tokens 57
6.8. Primer Factor 58
6.9. Aceptar Cookies 59
6.10. Datos del Usuario 60
6.11. Ingresar HOTP 61

Índice de Tablas

2.1. Comparación de Hardware FIDO2 26

Capítulo 1

Introducción

1.1. Contexto y Justificación

1.1.1. Avances tecnológico, Servicios y Credenciales

En el vertiginoso mundo digital de hoy, los avances tecnológicos han abierto un abanico de posibilidades en cuanto a los servicios disponibles en línea y las formas en que interactuamos con ellos. Desde la banca móvil hasta las compras en línea y las redes sociales, la proliferación de servicios digitales ha transformado la manera en que vivimos, trabajamos y nos relacionamos. Sin embargo, este panorama también ha planteado desafíos significativos en términos de seguridad, especialmente en lo que respecta a la autenticación en línea y la gestión de credenciales.

La autenticación, el proceso mediante el cual verificamos la identidad de un usuario para permitir el acceso a recursos en línea, se ha vuelto cada vez más compleja en respuesta a las crecientes amenazas cibernéticas y las demandas de los usuarios en busca de una experiencia más segura y conveniente. Los métodos de autenticación tradicionales, como las contraseñas, ya no son suficientes para hacer frente a los sofisticados ataques y las demandas de una sociedad digitalizada.

En este contexto, los avances tecnológicos juegan un papel crucial en la evolución de la autenticación en línea y la gestión de credenciales. Tecnologías como FIDO (Fast Identity Online) han surgido como una alternativa prometedora a las contraseñas tradicionales, ofreciendo un enfoque más seguro y conveniente basado en estándares abiertos y autenticación multifactorial. Combinado con plataformas de gestión de identidad y acceso como PrivacyIDEA, estos avances tecnológicos están redefiniendo los estándares de seguridad y usabilidad en la autenticación en línea.

En este trabajo, exploraremos los avances tecnológicos más recientes en el campo de la autenticación en línea y la gestión de credenciales. Analizaremos cómo estas tecnologías están transformando la forma en que nos autenticamos y accedemos a servicios en línea, y exa-

minaremos los beneficios y desafíos asociados con su implementación. A través de casos de estudio y análisis en profundidad, descubriremos cómo los servicios y las credenciales digitales están evolucionando para satisfacer las demandas de seguridad y usabilidad en la era digital.

1.1.2. Introducción al problema de seguridad en la autenticación en línea

En la actualidad, la creciente digitalización de nuestras vidas ha transformado la forma en que interactuamos con el mundo, facilitando el acceso a una amplia gama de servicios en línea, desde banca hasta redes sociales. Sin embargo, este panorama digital también ha dado lugar a una creciente preocupación por la seguridad de nuestros datos personales y financieros. En el corazón de esta preocupación se encuentra el proceso de autenticación en línea, que actúa como la primera línea de defensa contra el acceso no autorizado a nuestras cuentas y recursos digitales.

Los métodos de autenticación tradicionales, como las contraseñas, han sido durante mucho tiempo el pilar de la seguridad en línea. Sin embargo, su efectividad se ve cada vez más cuestionada debido a una serie de desafíos de seguridad, como contraseñas débiles, ataques de phishing y brechas de seguridad. Estos problemas ponen en riesgo la integridad de nuestras cuentas y datos, y exigen soluciones más sólidas y confiables.

Es en este contexto que surge la necesidad de explorar soluciones innovadoras que fortalezcan la seguridad de la autenticación en línea. Una de estas soluciones es FIDO (Fast Identity Online), un conjunto de estándares abiertos diseñados para ofrecer una autenticación más segura y conveniente que las contraseñas tradicionales. Combinado con PrivacyIDEA, una plataforma de gestión de identidad y autenticación de código abierto, estas soluciones prometen elevar el estándar de seguridad en la autenticación en línea.

En este trabajo, nos adentraremos en el mundo de la seguridad de la autenticación en línea, explorando los desafíos actuales y presentando una solución innovadora que utiliza FIDO y PrivacyIDEA para fortalecer la seguridad de la autenticación. A través de un análisis exhaustivo y estudios de caso, examinaremos cómo estas tecnologías pueden abordar los problemas de seguridad en la autenticación en línea y proporcionar una experiencia más segura y confiable para usuarios y organizaciones por igual.

1.2. Objetivos del TFG

Una vez comentado el tema principal de este Trabajo Final de Grado, me he propuesto una serie de objetivos a cumplir en el periodo de tiempo establecido. A continuación se listarán los objetivos fundamentales, los cuales se irán incluyendo posteriormente en las distintas fases establecidas en la planificación.

1.2.1. Objetivos Generales

- Desarrollar FIDO y PrivacyIDEA dentro del marco de SimpleSAMLphp, asegurando la conformidad con los estándares y requisitos del Esquema Nacional de Seguridad (ENS).
- Realizar pruebas exhaustivas para evaluar la eficacia y seguridad de la autenticación de dos factores mediante FIDO y PrivacyIDEA, en línea con las directrices del ENS.
- Analizar y comparar las distintas opciones existentes para adaptar el Proveedor de Identidad (IDP) de la Universidad de Huelva al ENS y desplegar la solución elegida, garantizando así la conformidad con los requisitos legales y normativos establecidos.

1.2.2. Objetivos Específicos

- Comparar los resultados obtenidos con otras formas de autenticación de dos factores, como el envío de SMS o correos electrónicos, para determinar ventajas y desventajas en términos de seguridad y usabilidad.
- Estudiar en profundidad el Esquema Nacional de Seguridad (ENS) para comprender sus implicaciones y requisitos específicos en materia de autenticación de dos factores.
- Analizar el estándar WebAuthn y su relevancia en el contexto de la autenticación de dos factores, con especial énfasis en su aplicación en entornos de SimpleSAMLphp.
- Explorar la relación entre los mecanismos de autenticación propuestos en el ENS y WebAuthn, identificando posibles sinergias y desafíos de implementación.

1.3. Enfoque y Método Seguido

Para alcanzar los objetivos establecidos, se seguirá un enfoque metodológico que integra la investigación teórica, el diseño y desarrollo práctico, así como la evaluación exhaustiva de los resultados obtenidos.

1. Desarrollo de FIDO y PrivacyIDEA en SimpleSAMLphp:
   - Se comenzará por investigar y comprender los requisitos técnicos y de integración de FIDO y PrivacyIDEA dentro del marco de SimpleSAMLphp.
   - Se procederá a la configuración e implementación de FIDO y PrivacyIDEA en el entorno de SimpleSAMLphp, asegurando la conformidad con los estándares y requisitos del Esquema Nacional de Seguridad (ENS).
2. Pruebas exhaustivas de autenticación de dos factores:

- Se diseñará un conjunto de pruebas exhaustivas para evaluar la eficacia y seguridad de la autenticación de dos factores mediante FIDO y PrivacyIDEA.
- Se llevarán a cabo pruebas de funcionalidad, interoperabilidad y seguridad para garantizar que la solución desarrollada cumpla con los estándares del ENS.

3. Comparación con otros métodos de autenticación:
   - Se establecerá un marco de referencia para comparar los resultados obtenidos con otras formas de autenticación de dos factores, como el envío de SMS o correos electrónicos.
   - Se realizarán pruebas comparativas para determinar las ventajas y desventajas en términos de seguridad y usabilidad de cada método.
4. Estudio del Esquema Nacional de Seguridad (ENS) y WebAuthn:
   - Se llevará a cabo un estudio detallado del marco legal y los requisitos específicos del ENS en materia de autenticación de dos factores.
   - Se analizará el estándar WebAuthn y su aplicación en el contexto de la autenticación de dos factores, con especial énfasis en su integración con SimpleSAMLphp.
5. Adaptación del IDP de la Universidad de Huelva al ENS:
   - Se explorarán y evaluarán diferentes opciones para adaptar el Proveedor de Identidad (IDP) de la Universidad de Huelva a los requisitos del ENS.
   - Se diseñará la solución elegida, asegurando la conformidad con los requisitos legales y normativos establecidos.

1.4. Planificación

1.4.1. Planificación de tares y división de tiempo

Fase 1: Investigación y Análisis (Meses 1-2):

- Realizar una revisión detallada de la literatura sobre FIDO, PrivacyIDEA y métodos de autenticación de dos factores.
- Analizar a fondo la arquitectura y los requisitos de SimpleSAMLphp para comprender su integración con FIDO y PrivacyIDEA.

Fase 2: Configuración y Despliegue (Mes 3):

- Instalar y configurar minuciosamente SimpleSAMLphp para preparar el entorno de desarrollo.
- Integrar de manera completa el módulo de PrivacyIDEA y configurar el servidor para la autenticación de dos factores.

Fase 3: Pruebas y Evaluación (Mes 4):

- Realizar pruebas exhaustivas de autenticación en diversos escenarios y casos de uso para evaluar la eficacia y seguridad de la solución desarrollada.
- Comparar de forma exhaustiva los resultados obtenidos con otros métodos de autenticación de dos factores para identificar ventajas y desventajas.
- Documentar de manera completa la implementación y los resultados obtenidos durante esta fase.

Fase 4: Presentación y Entrega (Mes 5):

- Preparar la presentación final del proyecto, incluyendo los hallazgos, conclusiones y recomendaciones.
- Entregar el Trabajo de Fin de Grado junto con la documentación detallada de la implementación y los resultados obtenidos.
- Defender oralmente el proyecto ante el tribunal académico.

1.4.2. Recursos Necesarios

Hardware:

- Máquinas virtuales para la instalación y configuración de SimpleSAMLphp y los servicios asociados.
- Dispositivos de prueba compatibles con FIDO para realizar pruebas exhaustivas de autenticación.

Software:

- SimpleSAMLphp y todos los componentes necesarios para su funcionamiento.
- Módulos de PrivacyIDEA y otros complementos requeridos para la autenticación de dos factores.
- Herramientas de desarrollo y pruebas para realizar evaluaciones exhaustivas de la solución implementada.

Tiempo:

- Tiempo suficiente para llevar a cabo todas las fases del proyecto, incluyendo investigación, configuración, pruebas y documentación.

Acceso a Documentación y Recursos en Línea:

- Acceso a documentación y recursos en línea relacionados con SimpleSAMLphp, FIDO, PrivacyIDEA y otros componentes utilizados en el proyecto.

1.5. Evolución de los Métodos de Autenticación

Desarrollo Histórico de Autenticación en orden cronológico [1]:

Métodos Criptográficos:

- Cifrado de César: Fue un método de cifrado por sustitución simple, su utilización histórica resalta la importancia de proteger la autenticidad de la comunicación.
- Máquina Enigma: fue crucial durante la Segunda Guerra Mundial para proteger la confidencialidad de la información. Si bien su uso se centraba en la encriptación de mensajes, su relevancia para la autenticación radica en el desarrollo de sistemas criptográficos más complejos y la comprensión de la necesidad de métodos de autenticación sólidos en entornos seguros.
- Desarrollo de la Criptografía Moderna: Los avances en criptografía moderna derivados de la experiencia histórica han influido en la autenticación. Por ejemplo, la autenticación multifactorial utiliza métodos criptográficos avanzados para proteger la identidad del usuario. Los algoritmos criptográficos actuales como RSA, AES, etc., se utilizan en sistemas de autenticación seguros para garantizar la integridad y confidencialidad de los datos de identificación.

Los métodos criptográficos no solo se utilizan para encriptar datos, sino también para verificar la identidad en sistemas de autenticación. Las firmas digitales, un componente de la criptografía, se utilizan para autenticar la identidad de una entidad o persona en entornos digitales [2].

Autenticación Biométrica: La autenticación biométrica se basa en la identificación única de características físicas o comportamientos biológicos para verificar la identidad de un individuo.

- Huellas Dactilares: La identificación mediante huellas dactilares se convirtió en uno de los métodos más comunes y confiables. La singularidad de las huellas digitales garantiza una identificación precisa y se aplicó ampliamente en áreas de seguridad, como el acceso a edificios y dispositivos.
- Reconocimiento Facial: Se realizaron avances en el reconocimiento facial, utilizando características únicas del rostro humano para la autenticación. Aunque inicialmente menos precisos, los sistemas de reconocimiento facial han mejorado significativamente con el tiempo.
- Escaneo del Iris: Debido a su singularidad y estabilidad a lo largo del tiempo, se convirtió en una forma altamente confiable de autenticación. Aunque inicialmente costoso y complejo, su precisión lo ha convertido en un método utilizado en aplicaciones de alta seguridad.
- Reconocimiento de Voz: Utilizando características únicas del habla de una persona, como tono, entonación y patrones de voz, el reconocimiento de voz se ha desarrollado para autenticación en sistemas de control de acceso y en dispositivos digitales.

Tarjetas de Identificación y Acceso: Se introdujeron como una solución eficiente para autenticar la identidad y regular el acceso a edificios, recursos o información confidencial. Estas tarjetas representaron un cambio significativo en la forma en que se gestionaba el control de acceso y la verificación de la identidad [3].

- Tarjetas de Acceso a Edificios: Las organizaciones adoptaron estas tarjetas para controlar y registrar el acceso a sus instalaciones. Permitieron un sistema de seguridad más eficaz al restringir la entrada a áreas sensibles y registrar el movimiento de empleados o visitantes.
- Tarjetas de Identificación Gubernamentales: Los gobiernos adoptaron las tarjetas de identificación como una forma de identificar a los ciudadanos, gestionar la información personal y regular el acceso a servicios gubernamentales y beneficios sociales.
- Tarjetas de Empleados: Muchas empresas comenzaron a emitir tarjetas de identificación para sus empleados, incluyendo información personal, acceso a áreas restringidas y en algunos casos, funciones de pago o control de tiempo.
- Tarjetas de Proximidad (RFID): La integración de tecnologías como RFID (Identificación por Radiofrecuencia) ha permitido un acceso más rápido y sin contacto a áreas restringidas.
- Migración a Soluciones Digitales: Con el avance tecnológico, se está produciendo una migración gradual de las tarjetas físicas hacia soluciones de autenticación digital, como aplicaciones móviles o tokens virtuales.

Contraseñas Digitales: A medida que se multiplicaba el número de contraseñas utilizadas en diferentes sistemas, surgió el desafío de gestionarlas de manera segura, lo que llevó al desarrollo de soluciones de gestión de contraseñas.
Las contraseñas también se convirtieron en un punto de vulnerabilidad debido a la posibilidad de ataques de fuerza bruta, phishing y violaciones de seguridad[4].
Integración con Tecnologías Modernas:

- Autenticación Multifactorial: A medida que se buscan formas más seguras de autenticación, las contraseñas se utilizan en combinación con otros factores, como la autenticación biométrica o los tokens, para fortalecer la seguridad.
- Enfoque en la Seguridad Adicional: Se están desarrollando sistemas de autenticación más avanzados para complementar o reemplazar las contraseñas, aunque su implementación completa puede llevar tiempo debido a la infraestructura existente basada en contraseñas.

Tokens y Dispositivos de Autenticación: Con la creciente necesidad de seguridad en línea, se ha producido un desarrollo significativo de tokens y dispositivos específicamente diseñados para fortalecer los sistemas de autenticación en entornos digitales.
Tipos de Dispositivos de Autenticación:

- Tokens Electrónicos: Estos dispositivos físicos generan códigos aleatorios que cambian periódicamente y son utilizados como segundo factor de autenticación en sistemas en línea. Pueden ser hardware dedicado o aplicaciones móviles que emulan su funcionalidad.

- Tarjetas Inteligentes: Basadas en chips integrados, estas tarjetas almacenan datos de autenticación y pueden utilizarse en lectores específicos o incorporados en dispositivos móviles para autenticación segura.

- USB de Autenticación: Dispositivos USB con funciones de autenticación que, al ser conectados a un sistema, verifican la identidad del usuario para permitir el acceso a recursos protegidos.

- Tokens Móviles: Aplicaciones móviles que generan códigos de autenticación o utilizan tecnologías como NFC para habilitar la autenticación mediante el teléfono móvil del usuario.

- Generadores de Códigos: Estos dispositivos generan códigos únicos y temporales que se utilizan como segundo factor de autenticación, ofreciendo mayor seguridad en comparación con las contraseñas estáticas.

Métodos de Autenticación Avanzada: Tecnologías emergentes como FIDO (Fast Identity Online), PrivacyIDEA, autenticación basada en la nube, machine learning y sistemas adaptativos de autenticación[5].

- FIDO (Fast Identity Online): Es un conjunto de estándares diseñados para permitir la autenticación fuerte y segura sin depender de contraseñas. Se basa en métodos como la autenticación biométrica y tokens de seguridad.
  Utiliza claves criptográficas públicas y privadas únicas para cada servicio o sitio web, asegurando una autenticación segura y sin compartir secretos entre servicios.

- PrivacyIDEA: Es una plataforma de código abierto que ofrece soluciones flexibles de autenticación multifactorial. Permite la integración con diversos proveedores y métodos de autenticación.
  Proporciona opciones de autenticación versátiles, incluyendo OTP (One-Time Passwords), autenticación SMS, autenticación push, tarjetas inteligentes y más.

- Autenticación Basada en la Nube: Este enfoque utiliza soluciones de autenticación alojadas en la nube, permitiendo a los usuarios acceder a recursos desde cualquier ubicación.
  Utiliza servicios de autenticación remota para verificar la identidad del usuario, permitiendo el acceso a aplicaciones y datos en la nube de manera segura.

- Machine Learning en la Autenticación: La inteligencia artificial y el machine learning se están utilizando para mejorar la autenticación al analizar patrones de comportamiento del usuario y detectar anomalías.
  Los sistemas de autenticación adaptativos aprenden del comportamiento del usuario y

pueden detectar actividades sospechosas basadas en desviaciones del comportamiento normal.

- Sistemas Adaptativos de Autenticación: Estos sistemas se ajustan continuamente a los patrones de autenticación del usuario y a las condiciones del entorno para mejorar la seguridad.
  Adaptan las políticas de autenticación basadas en la evaluación de riesgos en tiempo real, solicitando una autenticación más fuerte en situaciones de mayor riesgo.

Capítulo 2

FIDO 2

2.1. Introducción FIDO 2

2.1.1. Que es y su Importancia en linea

En 2009, Google fue objeto de sofisticados ciberataques capaces de eludir los controles de seguridad tradicionales [7]. Ante la falta de opciones viables de autenticación de dos factores (2FA) para prevenir eficazmente estos ataques y apropiaciones de cuentas, Google comenzó a trabajar en estrecha colaboración con Alianza FIDO[1] para ampliar las capacidades de la tecnología de autenticación de dos factores YubiKey para incluir también la criptografía de clave pública. A través de esta colaboración, crearon conjuntamente un protocolo de autenticación sólido basado en el concepto de una clave única resistente al phishing para proteger todos los servicios[8]. Es este trabajo el que más tarde se convirtió en un estándar abierto adoptado por la alianza FIDO llamado estándar FIDO Universal 2nd Factor (U2F).
Una sola YubiKey puede proteger una multitud de servicios en línea sin información del usuario ni claves privadas compartidas entre los proveedores de servicios. No existe dependencia ni requisito de conectividad móvil, dispositivos celulares, aplicaciones móviles o ingreso manual de códigos.

Hoy en día, Google no solo protege a los empleados con YubiKey, sino que también ha integrado soporte para las claves de seguridad YubiKey y FIDO U2F en las protecciones de seguridad disponibles para todos los usuarios de Google. Cualquier usuario con una cuenta de Google ahora puede protegerse del phishing avanzado y beneficiarse de la autenticación sólida proporcionada por YubiKey[7].

Google lanzó su Programa de Protección Avanzada (GAPP) para aquellos usuarios con mayor riesgo, incluidos periodistas, líderes empresariales y equipos de campañas políticas. El programa GAPP refuerza aún más la seguridad para los usuarios de cuentas de Google al exigir el uso de claves de seguridad respaldadas por hardware para un inicio de sesión seguro en lugar de hacerlas opcionales. Para brindar la defensa más sólida contra el phishing, la Pro-

[1] Entre los que están Yubico, Amazon, Mozilla, Alibaba o Facebook

tección avanzada va más allá de la verificación tradicional en dos pasos. Los participantes de GAPP deben iniciar sesión en su cuenta con una contraseña y una clave de seguridad física, es decir, YubiKey. Otros factores de autenticación, incluidos los códigos enviados por SMS o la aplicación Google Authenticator, ya no funcionarán, ya que se ha demostrado que estas formas de 2FA son susceptibles de phishing[9].

FIDO2, abreviatura de Fast Identity Online 2, es una especificación de autenticación en línea desarrollada por la FIDO Alliance, una coalición de empresas líderes en tecnología que busca mejorar la seguridad de la autenticación en línea. Esta especificación tiene como objetivo principal proporcionar una forma más segura, sencilla y conveniente de autenticar usuarios en servicios en línea, eliminando la dependencia de las contraseñas y reduciendo así los riesgos asociados con su uso.

En esencia, FIDO2 es un conjunto de estándares abiertos que permiten a los usuarios autenticarse en línea de manera segura utilizando métodos de autenticación más avanzados, como la biometría[2] y llaves de seguridad físicas[3]. Estos métodos son mucho más seguros que las contraseñas tradicionales, que pueden ser fácilmente comprometidas por ataques de phishing, ingeniería social o brechas de datos[12].

FIDO2 es una especificación innovadora que está transformando la forma en que nos autenticamos en línea. Al ofrecer una combinación de seguridad mejorada, facilidad de uso y eliminación de contraseñas, FIDO2 tiene el potencial de mejorar significativamente la seguridad y la experiencia del usuario en el mundo digital. Su importancia radica en su capacidad para abordar los desafíos de seguridad asociados con las contraseñas tradicionales y proporcionar una alternativa más segura y conveniente para la autenticación en línea.

FIDO2 aseguran el acceso a computadoras, redes y servicios en línea para miles de empresas y millones de usuarios en 160 países. Contamos con la confianza principales empresas de Internet e instituciones a nivel mundial[12].

2.1.2. Problemas de seguridad con métodos y contraseñas tradicionales

En el mundo digital actual, los métodos de autenticación tradicionales, especialmente aquellos basados en contraseñas, presentan una serie de problemas de seguridad que comprometen la integridad y la confidencialidad de los datos de los usuarios[13]. Estos problemas son cada vez más evidentes a medida que la tecnología avanza y los ciberdelincuentes desarrollan métodos más sofisticados para comprometer la seguridad en línea. El 54 % de los consumidores han notado que los mensajes de phishing se han vuelto más sofisticados[10].

Uno de los problemas más destacados es la vulnerabilidad a ataques de fuerza bruta y de diccionario. Las contraseñas tradicionales suelen ser cortas, predecibles o fácilmente derivables

[2] Como el escaneo de huellas dactilares o el reconocimiento facial
[3] Como las llaves de seguridad USB

a partir de información personal, lo que las hace susceptibles a ser adivinadas por programas automatizados que prueban una gran cantidad de combinaciones en poco tiempo. Este tipo de ataque puede comprometer fácilmente una cuenta si la contraseña es débil o estándar[14].

Otro desafío importante es la reutilización de contraseñas. Muchos usuarios tienden a usar la misma contraseña para múltiples cuentas en línea, lo que aumenta el riesgo de que una sola brecha de seguridad pueda comprometer múltiples cuentas. Si un atacante obtiene acceso a una contraseña mediante una brecha de datos, puede intentar utilizarla en otras cuentas del mismo usuario, potencialmente causando daños extensos. El 81 % Las infracciones relacionadas con la piratería son causadas por contraseñas débiles o robadas[10].

Los ataques de phishing y de ingeniería social son también una preocupación significativa. Los usuarios pueden ser engañados para revelar sus contraseñas u otra información confidencial mediante correos electrónicos falsos, sitios web fraudulentos o llamadas telefónicas engañosas. Estos ataques son especialmente peligrosos porque explotan la confianza del usuario y pueden ser difíciles de detectar. Desde el cuarto trimestre de 2022 aumentó 1,265 % de los correos electrónicos de phishing maliciosos y un aumento del 967 % del phishing de credenciales[10].

Las brechas de datos representan otro riesgo importante para la seguridad en línea. Estos eventos ocurren cuando los datos confidenciales de los usuarios, incluidas las contraseñas, son comprometidos y expuestos a terceros no autorizados. Las brechas de datos pueden ocurrir en una amplia variedad de organizaciones, desde grandes corporaciones hasta pequeñas empresas, y pueden tener consecuencias devastadoras para los usuarios cuyos datos se ven comprometidos[15].

La dificultad para recordar contraseñas seguras también es un desafío común para muchos usuarios. Las recomendaciones de seguridad sugieren el uso de contraseñas largas y complejas, pero recordar múltiples contraseñas de este tipo puede ser una tarea abrumadora. Como resultado, los usuarios a menudo optan por contraseñas más simples y fáciles de recordar, comprometiendo así la seguridad de sus cuentas. Con FIDO esto mejora, con un 4x en la mejora en la tasa de éxito del inicio de sesión (frente a las contraseñas) y un 95 % de reducción de restablecimiento de contraseña[10].

Finalmente, los ataques de suplantación de identidad son una preocupación creciente en el panorama de seguridad en línea. Los atacantes pueden utilizar información robada, como contraseñas comprometidas o datos personales, para hacerse pasar por un usuario legítimo y acceder a sus cuentas en línea. Este tipo de ataque puede ser especialmente perjudicial, ya que permite a los atacantes realizar actividades maliciosas en nombre del usuario legítimo.

2.2. Componentes FIDO 2

2.2.1. WebAuth y CTAP

WebAuthn (Web Authentication):
WebAuthn, o Web Authentication, es una especificación web desarrollada por el World Wide Web Consortium (W3C) que permite a los usuarios autenticarse en sitios web y aplicaciones utilizando métodos de autenticación más seguros, como la biometría y las llaves de seguridad físicas, en lugar de contraseñas tradicionales. Fue diseñado para mejorar la seguridad en línea y simplificar la experiencia del usuario al eliminar la necesidad de recordar contraseñas complejas[16].

- Seguridad Mejorada: Al eliminar la necesidad de contraseñas y utilizar métodos de autenticación más seguros, como la biometría y las llaves de seguridad físicas, WebAuthn mejora significativamente la seguridad en línea.
- Experiencia del Usuario Mejorada: Al simplificar el proceso de autenticación y eliminar la necesidad de recordar contraseñas, WebAuthn proporciona una experiencia del usuario más conveniente y sin fricciones.
- Protección contra Phishing: Los métodos de autenticación avanzados utilizados por WebAuthn ayudan a proteger contra los ataques de phishing, ya que los usuarios no necesitan ingresar sus contraseñas en sitios web fraudulentos.

CTAP (Client to Authenticator Protocol):
CTAP, o Client to Authenticator Protocol, es un protocolo de comunicación desarrollado por la FIDO Alliance que permite la interoperabilidad entre los clientes web y los autenticadores, como las llaves de seguridad físicas, en el contexto de FIDO2. CTAP se utiliza en conjunción con WebAuthn para permitir la autenticación sin contraseña en línea[17].

- Comunicación Segura: CTAP proporciona una interfaz segura entre el cliente web (como un navegador) y el autenticador (como una llave de seguridad física). Utiliza técnicas de cifrado y autenticación fuerte para garantizar la seguridad de la comunicación entre ambos dispositivos.
- Interoperabilidad: Al ser una especificación abierta y basada en estándares, CTAP promueve la interoperabilidad entre diferentes dispositivos y plataformas. Esto permite que los usuarios utilicen una variedad de autenticadores compatibles con CTAP para autenticarse en línea.
- Soporte para Múltiples Factores de Autenticación: CTAP permite la autenticación multifactorial al admitir una amplia gama de métodos de autenticación, incluidos factores como la biometría y las llaves de seguridad físicas.

La Figura 2.1 muestra el flujo de autenticación utilizando WebAuthn y CTAP.

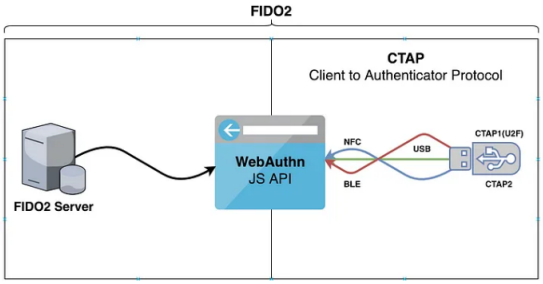

Figura 2.1: Authentication Flow

2.2.2. Funcionamiento en conjunto

WebAuthn y CTAP son dos componentes clave de FIDO2 que trabajan en conjunto para proporcionar una autenticación en línea más segura, conveniente y sin contraseñas. Ambos protocolos se complementan entre sí para permitir a los usuarios autenticarse en sitios web y aplicaciones utilizando métodos de autenticación más avanzados, como la biometría y las llaves de seguridad físicas. En la figura 2.2 (obtenida de [18]) se muestra como se comunican y a continuación, se detalla extensamente cómo funcionan en conjunto:

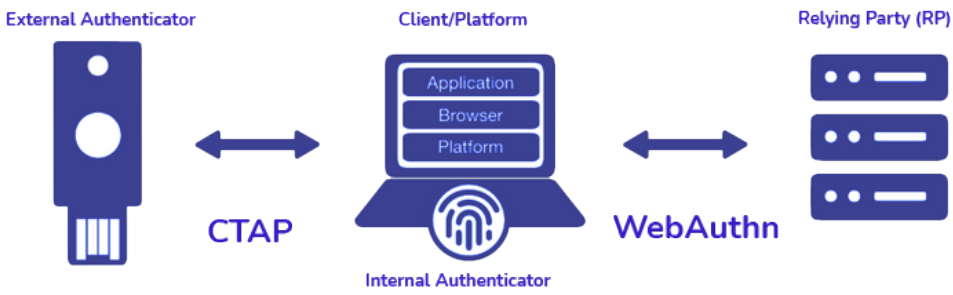

Figura 2.2: Comunicación FIDO2

1. Solicitud de Autenticación:
   - El proceso de autenticación comienza cuando un usuario intenta acceder a un servicio en línea que admite WebAuthn.
   - El sitio web o la aplicación envía una solicitud de autenticación al navegador web del usuario, indicando que se requiere una autenticación segura y que se admiten métodos de autenticación sin contraseña.
2. Selección de Método de Autenticación:
   - El navegador web del usuario presenta una lista de métodos de autenticación compatibles, como la biometría o las llaves de seguridad físicas, que pueden utilizarse para autenticarse en el sitio web.

- El usuario selecciona el método de autenticación deseado, que puede ser una huella dactilar, reconocimiento facial o la inserción de una llave de seguridad física.

3. Interacción con el Autenticador:
   - Una vez seleccionado el método de autenticación, el navegador web inicia una comunicación segura con el autenticador del usuario utilizando el protocolo CTAP.
   - El autenticador verifica la identidad del usuario utilizando el método de autenticación seleccionado. Por ejemplo, si se utiliza una llave de seguridad física, el autenticador puede requerir que el usuario presione un botón en la llave para confirmar su identidad.
4. Generación de Credencial Criptográfica:
   - Una vez verificada la identidad del usuario, el autenticador genera una credencial criptográfica única que se utiliza para autenticar al usuario en el futuro.
   - Esta credencial criptográfica se almacena de forma segura en el dispositivo del usuario y se utiliza como prueba de la identidad del usuario durante las futuras solicitudes de autenticación.
5. Retorno al Sitio Web o Aplicación:
   - Una vez completado el proceso de autenticación, el autenticador devuelve la credencial criptográfica al navegador web del usuario.
   - El navegador web envía la credencial criptográfica al sitio web o aplicación para verificar la identidad del usuario y permitirle acceder al servicio en línea.
6. Autenticación Exitosa:
   - Si la credencial criptográfica proporcionada por el usuario coincide con la credencial almacenada previamente en el proceso de registro, el sitio web o la aplicación autentica al usuario y le otorga acceso al servicio en línea.
   - El usuario puede ahora acceder al servicio en línea de manera segura y conveniente, sin la necesidad de recordar contraseñas complejas o preocuparse por la seguridad de su cuenta[4].

2.3. Criptografía Subyacente

La criptografía subyacente en FIDO2 es fundamental para garantizar la seguridad y la integridad del proceso de autenticación sin contraseña. Esta criptografía se utiliza en varios aspectos de FIDO2, incluida la generación de credenciales criptográficas, la autenticación de

[4] Es importante destacar que la credencial criptográfica está diseñada para ser única para cada usuario y servicio, lo que significa que incluso si un atacante obtiene acceso a la credencial criptográfica de un usuario para un servicio específico, esta credencial no debería ser útil para autenticarse en otros servicios o cuentas

usuarios y la protección de la comunicación entre el cliente y el servidor. Exploraremos en detalle los principales componentes y conceptos de la criptografía subyacente en FIDO2.

2.3.1. Detalles sobre ECC

La Criptografía de Curva Elíptica es una rama de la criptografía que utiliza propiedades matemáticas de las curvas elípticas sobre cuerpos finitos para cifrar, firmar digitalmente y autenticar datos de manera segura. Desde su introducción en la década de 1980, ECC ha ganado popularidad debido a su eficiencia, seguridad y capacidad para proporcionar niveles de seguridad similares a algoritmos más antiguos, pero con claves más cortas. Exploraremos a continuación con gran detalle los conceptos clave relacionados con ECC[19].

Una de las principales ventajas de ECC es su eficiencia en términos de rendimiento y tamaño de clave. Las claves ECC son considerablemente más cortas que las claves RSA equivalentes, lo que resulta en una menor carga computacional y una menor cantidad de datos transmitidos. ECC se utiliza en una variedad de aplicaciones criptográficas, incluida la firma digital, el intercambio de claves y el cifrado de datos. Es ampliamente utilizado en protocolos de seguridad como TLS/SSL, PGP, SSH y Bitcoin, entre otros.

En FIDO2, ECC se utiliza para generar claves criptográficas en el proceso de autenticación sin contraseña, proporcionando un nivel adicional de seguridad y privacidad para los usuarios en línea.

2.3.2. Detalles sobre HMAC

El Código de Autenticación de Mensajes basado en Hash es un algoritmo de autenticación de mensajes que utiliza una función hash criptográfica en combinación con una clave secreta para verificar la integridad y autenticidad de los datos transmitidos entre dos partes. El HMAC es ampliamente utilizado en aplicaciones de seguridad para proteger contra la modificación y falsificación de datos durante la transmisión. A continuación, exploraremos en detalle los aspectos clave relacionados con HMAC[20].

La seguridad del HMAC depende en gran medida de la fortaleza de la función hash criptográfica subyacente y de la longitud y entropía de la clave secreta utilizada.Los algoritmos de hash criptográficos modernos, como SHA-256 y SHA-512, son ampliamente considerados seguros y resistentes a una amplia gama de ataques criptográficos. La clave secreta utilizada en el HMAC debe ser lo suficientemente larga y aleatoria para resistir los ataques de fuerza bruta y de búsqueda de claves[21].

El HMAC se utiliza en una variedad de aplicaciones de seguridad, incluyendo la autenticación de mensajes en protocolos de red como TLS/SSL, la protección de contraseñas almacenadas en bases de datos, la verificación de la integridad de archivos y la autenticación de mensajes en sistemas de mensajería segura. En el contexto de FIDO2 y la autenticación sin

contraseña, el HMAC puede utilizarse para proteger la integridad de los datos transmitidos durante el proceso de autenticación entre el cliente y el servidor.

2.4. Tipos de dispositivos Hardware

2.4.1. Descripción de todos los dispositivos hardware

Llave de seguridad configurable todo en uno. Con un simple toque, YubiKey multiprotocolo protege el acceso a computadoras, redes y servicios en línea.[22]

Más fácil y seguro que las aplicaciones de autenticación. Con estos dispositivos no es necesario buscar el teléfono ni volver a escribir contraseñas. Simplemente es necesario conectar el YubiKey y tocar en él. YubiKey funciona con con cientos de servicios, el inicio de sesión de Windows y Mac, Gmail, Dropbox, Facebook, Salesforce, Duo y muchos más servicios.

Serie YubiKey 5:
La llave de seguridad multiprotocolo número uno del mundo. La serie YubiKey 5 elimina la apropiación de cuentas al proporcionar una sólida defensa contra el phishing utilizando capacidades multiprotocolo que pueden proteger los sistemas modernos y heredados. La serie ofrece una variedad de opciones de autenticación que incluyen autenticación sólida de dos factores, múltiples factores y sin contraseña, y un toque para firmar sin interrupciones.

- Soporte multiprotocolo; FIDO2, U2F, tarjeta inteligente, OTP, OpenPGP 3
- USB-A, USB-C, NFC, Lightning
- Clasificación IP68, resistente al aplastamiento, no requiere baterías ni piezas móviles

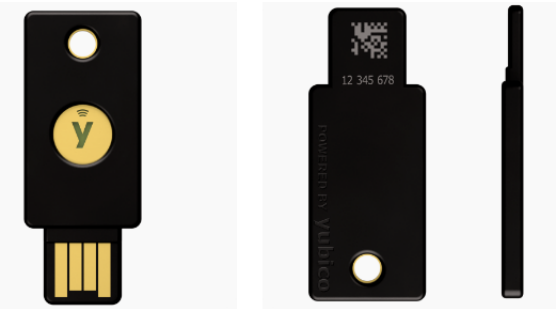

Figura 2.3: Serie Yubikey 5

Serie YubiKey 5 FIPS:
Las llaves de seguridad certificadas FIPS YubiKey 5 cumplen con el más alto nivel de seguridad (AAL3) de las nuevas pautas NIST SP800-63B.

- Adecuado para el gobierno y las industrias reguladas

- Soporte multiprotocolo, tarjeta inteligente, OTP, OpenPGP, FIDO U2F, FIDO2/WebAuthn
- USB-A, USB-C, Lightning, NFC

Figura 2.4: YubiKey 5 FIPS Series

Serie biológica de YubiKey:
YubiKey Bio Series admite autenticación biométrica mediante reconocimiento de huellas dactilares para inicios de sesión seguros y sin contraseña. Creada principalmente para computadoras de escritorio y diseñada para ofrecer sólidas opciones de autenticación biométrica, la serie YubiKey Bio ofrece la seguridad de hardware característica de Yubico, combinada con una nueva experiencia de usuario.

- Cumple con los requisitos de seguridad de hardware más estrictos con plantillas de huellas dactilares almacenadas en el elemento seguro de la llave.
- Funciona de inmediato con sistemas operativos y navegadores, incluidos Windows, macOS, Chrome OS, Linux, Chrome y Edge.
- Soporta FIDO2/WebAuthn, FIDO U2F
- Disponible en factores de forma USB-A y USB-C con soporte biométrico

Figura 2.5: YubiKey Bio Series

Serie YubiKey 5 CSPN:
La serie YubiKey 5 CSPN elimina la apropiación de cuentas y facilita la implementación de una autenticación sólida y escalable y protege a las organizaciones de ataques de phishing.

- Soporte multiprotocolo en FIDO2/WebAuthn, FIDO U2F, Smart Card y OTP
- Soporte para inicio de sesión seguro sin contraseña con tarjeta inteligente y autenticación FIDO2/WebAuthn
- Capacidad para trabajar en Microsoft Windows, macOS, Android y Linux, así como en los principales navegadores.
- Elección entre seis factores de forma que permiten a los usuarios conectarse a través de USB-A, USB-C, NFC y Lightning

Figura 2.6: Serie YubiKey 5 CSPN

Serie de llaves de seguridad:
La serie Security Key de Yubico ofrece llaves de seguridad exclusivas de FIDO tanto para consumidores como para empresas. Estas claves combinan autenticación basada en hardware, criptografía de clave pública y protocolos de autenticación modernos para eliminar la apropiación de cuentas.

- Protege Google Workspace, Microsoft 365, las principales plataformas IAM, administradores de contraseñas, aplicaciones de redes sociales y cientos de otros servicios.
- Soporta FIDO2/WebAuthn y FIDO U2F
- Funciona en computadoras de escritorio y dispositivos móviles con autenticación tap-and-go para teléfonos móviles
- Altamente duradero con resistencia al agua y al aplastamiento.
- Teclas de conector dual USB-A/NFC y USB-C/NFC
- Las claves de la edición Enterprise ofrecen numeración de serie; disponible solo con suscripción YubiEnterprise

Figura 2.7: Security Key Series

YubiHSM 2 y YubiHSM 2 FIPS:
Protección criptográfica revolucionaria para servidores, aplicaciones y dispositivos informáticos.

- Protección mejorada para claves criptográficas
- Integración rápida con seguridad respaldada por hardware
- Implementación simplificada para organizaciones de todos los tamaños
- Disponible en versiones FIPS y no FIPS con el mismo conjunto de funciones

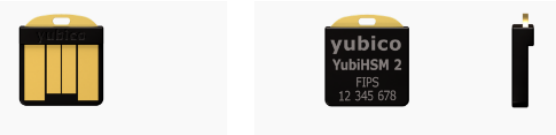

Figura 2.8: YubiHSM 2 Series

2.4.2. Comparación de los dispositivos hardware

Cuadro 2.1: Comparación de Hardware FIDO2

Comparación de Hardware FIDO2				
Dispositivos / Características	**Seguridad**	**Facilidad de Uso**	**Portabilidad**	**Integración**
YubiKey 5 Series	Autenticación sólida con soporte para múltiples protocolos y resistencia de hardware.	Fácil de usar, rápido y fiable, con opciones de autenticación simples como tocar y conectar.	Viene en diferentes formas, incluyendo USB, NFC y USB-C, para adaptarse a las necesidades del usuario.	Se integra con una amplia gama de sistemas y aplicaciones, incluyendo sistemas operativos y navegadores.

Continuación de la tabla 2.1				
Características / Dispositivos	**Seguridad**	**Facilidad de Uso**	**Portabilidad**	**Integración**
YubiKey 5 FIPS Series	Cumple con estándares de seguridad específicos como FIPS, autenticación resistente a phishing y soporte para múltiples protocolos.	Fácil de implementar y compatible con una amplia gama de dispositivos y plataformas.	Ofrece opciones de conectividad USB-A, USB-C, NFC y Lightning para su uso en una amplia variedad de dispositivos.	Es compatible con sistemas operativos principales y plataformas de navegadores para una fácil integración.
YubiKey Bio Series	Autenticación biométrica y PIN, resistencia de hardware y soporte para múltiples protocolos.	Proporciona una experiencia de autenticación sin fricciones a través de la autenticación biométrica y el PIN.	Proporciona una autenticación segura en dispositivos móviles y de escritorio, con opciones de conectividad USB y NFC.	Se integra con aplicaciones y servicios que admiten autenticación biométrica y PIN.
YubiKey 5 CSPN Series	Protección contra suplantación de identidad, adecuado para entornos empresariales sensibles y soporte para múltiples protocolos.	Fácil de implementar y se adapta a entornos empresariales de cualquier tamaño.	Portátil y se puede usar en una amplia gama de sistemas y aplicaciones.	Se integra con sistemas empresariales y aplicaciones en la nube para proteger el acceso a cuentas sensibles.
Security Key Series	Autenticación basada en hardware con criptografía de clave pública y soporte para múltiples protocolos.	Funciona sin necesidad de instalar software adicional y es compatible con cientos de servicios.	Ofrece soporte para dispositivos de escritorio y móviles con opciones de autenticación mediante USB y NFC.	Se integra con una amplia variedad de servicios que admiten protocolos FIDO para una fácil implementación.

2.5. Comparación con otros métodos de autenticación

Comparar los dispositivos FIDO2 con métodos de autenticación tradicionales en términos de seguridad, usabilidad y conveniencia nos permite comprender mejor las fortalezas y debilidades de cada enfoque.

Seguridad:

- Contraseñas: Las contraseñas son susceptibles a diversos ataques, como el phishing, el robo de contraseñas y los ataques de fuerza bruta. La seguridad de las contraseñas depende en gran medida de la complejidad y la gestión adecuada por parte del usuario.
- 2FA: La autenticación de dos factores mejora la seguridad al requerir un segundo factor, pero algunos métodos de 2FA, como los códigos SMS, son menos seguros debido a la posibilidad de interceptación. Sin embargo, aún proporciona una capa adicional de protección en comparación con las contraseñas solas.
- Biométrica: La autenticación biométrica ofrece un alto nivel de seguridad al basarse en características físicas únicas del individuo, como huellas dactilares o rasgos faciales. Sin embargo, la precisión y la fiabilidad pueden variar según el método biométrico utilizado y las condiciones ambientales.

Dispositivos FIDO2:

- Utilizan criptografía de clave pública y autenticación basada en hardware, lo que los hace menos susceptibles a ataques como el phishing y el robo de contraseñas.
- Los datos biométricos o de autenticación nunca abandonan el dispositivo, lo que reduce significativamente el riesgo de exposición.
- Ofrecen una autenticación sin fricciones y rápida, lo que reduce la posibilidad de ataques basados en el tiempo, como la suplantación de identidad.

Usabilidad:

- Contraseñas: Las contraseñas requieren que los usuarios las recuerden o las almacenen de manera segura, lo que puede resultar engorroso si se utilizan múltiples contraseñas complejas. La gestión de contraseñas puede ser una tarea difícil y propensa a errores.
- 2FA: La 2FA puede agregar una capa adicional de complejidad al proceso de inicio de sesión, ya que requiere un segundo paso después de ingresar la contraseña. Sin embargo, muchos métodos de 2FA son relativamente fáciles de usar, como las aplicaciones de autenticación móvil.
- Biométrica: La autenticación biométrica es conveniente para los usuarios, ya que elimina la necesidad de recordar contraseñas o llevar dispositivos adicionales. Sin embargo, la precisión y la velocidad pueden variar según el método biométrico y el dispositivo utilizado.

2.6. Ventajas y Desafíos

Ventajas y Beneficios para Usuarios, Empresas y Proveedores de Servicios[23]:

Usuarios:

- Seguridad Mejorada: Los usuarios disfrutan de una mayor seguridad al utilizar dispositivos FIDO2, ya que ofrecen una autenticación más robusta y resistente a los ataques de phishing y robo de contraseñas.
- Experiencia de Usuario Mejorada: La autenticación sin fricciones y rápida proporcionada por los dispositivos FIDO2 mejora la experiencia del usuario al eliminar la necesidad de recordar contraseñas complejas o llevar dispositivos adicionales.
- Conveniencia: Los usuarios pueden acceder a sus cuentas de manera rápida y sencilla con solo tocar un dispositivo o conectándolo a través de USB o NFC, lo que simplifica el proceso de inicio de sesión.

Empresas:

- Reducción de Riesgos: La implementación de dispositivos FIDO2 ayuda a reducir el riesgo de brechas de seguridad y el robo de datos al proporcionar una autenticación más segura y resistente a los ataques.
- Reducción de Costos: Al reducir la necesidad de soporte técnico relacionado con la gestión de contraseñas y las brechas de seguridad, las empresas pueden ahorrar en costos operativos y de infraestructura.
- Cumplimiento Regulatorio: Los dispositivos FIDO2 pueden ayudar a las empresas a cumplir con los requisitos regulatorios de seguridad de datos al proporcionar una autenticación más sólida y segura.

Proveedores de Servicios:

- Protección de la Marca: Al ofrecer autenticación segura a través de dispositivos FIDO2, los proveedores de servicios pueden proteger su marca al garantizar la seguridad de los datos del usuario.
- Mejora de la Confianza del Cliente: La implementación de medidas de seguridad robustas, como la autenticación FIDO2, puede mejorar la confianza del cliente al demostrar un compromiso con la protección de datos y la privacidad.
- Diferenciación Competitiva: Los proveedores de servicios que ofrecen autenticación avanzada a través de dispositivos FIDO2 pueden diferenciarse de la competencia al proporcionar una experiencia de usuario mejorada y una mayor seguridad.

Desafíos y Obstáculos:

- Adopción y Educación del Usuario: La falta de conciencia y comprensión sobre la autenticación FIDO2 puede obstaculizar su adopción. Es necesario educar a los usuarios sobre los beneficios y el funcionamiento de estos dispositivos.
- Compatibilidad y Integración: Algunas plataformas y servicios pueden no ser totalmente compatibles con la autenticación FIDO2, lo que puede dificultar su implementación en ciertos entornos.
- Costo Inicial: La adquisición de dispositivos FIDO2 puede representar un costo inicial para las empresas y los usuarios, lo que puede ser un obstáculo para su adopción generalizada.
- Experiencia del Usuario: Aunque la autenticación FIDO2 generalmente ofrece una experiencia de usuario mejorada, algunos usuarios pueden encontrar el proceso inicial de configuración y registro confuso o engorroso.

Capítulo 3

WebAuthn

3.1. Introducción al estándar WebAuthn

El 4 de marzo de 2019 [24], el World Wide Web Consortium (W3C) y la Alianza FIDO anunciaron la transición del proyecto Web Authentication a un estándar oficial de la web. Este estándar, destinado a hacer que la web sea más segura y fácil de usar, introduce una interfaz para implementar una autenticación más simple y sólida que los métodos tradicionales, como las contraseñas.
En este capítulo, exploraremos el marco teórico de la especificación de WebAuthn, dividido en secciones que abordan diversos aspectos relacionados. A medida que avancemos, comprenderemos las funcionalidades y responsabilidades de cada componente que conforma este estándar.

WebAuthn es una estandarización de una API que permite la creación y el uso de credenciales basadas en criptografía asimétrica (pública) para plataformas y aplicaciones web. Su propósito es proporcionar un sistema seguro de autenticación y registro, con la capacidad de prescindir de contraseñas y, por ende, eliminar las amenazas asociadas a estas.

El funcionamiento de WebAuthn es relativamente simple. A través de su interfaz, el agente de usuario (navegador del cliente) puede enviar acciones al autenticador (token físico de seguridad), que se encarga de crear y almacenar un par de claves (pública y privada), junto con otra información relevante. Posteriormente, solo el origen puede acceder y utilizar estas claves alojadas en el token.

Las partes confiables, como los servidores y las páginas web, pueden utilizar la API de WebAuthn para dos propósitos principales: registro y autenticación. En el caso del registro, se genera un nuevo par de claves asociado con el origen, mientras que en la autenticación, la plataforma verifica la presencia y el consentimiento del usuario enviando un desafío al autenticador, que responde con la firma del desafío utilizando la clave privada correspondiente.

Los autenticadores/tokens compatibles implementan una serie de métodos para proteger las

credenciales almacenadas e interactuar con los agentes de usuario a través de la API de WebAuthn. Estos autenticadores pueden estar integrados en el mismo dispositivo o ser dispositivos externos que se comuniquen a través de diferentes modos de transporte, como USB, Bluetooth o NFC.

Es importante destacar que en este método de autenticación no se envía ninguna información secreta (como la clave privada o la contraseña) a través de la red, lo que proporciona un nivel de seguridad superior en comparación con otros métodos tradicionales.

3.2. Web Authenticación Api

En esta sección, exploraremos en detalle los procesos de registro y autenticación utilizando la API de WebAuthn desde el punto de vista del cliente, así como los requisitos y flujos de comunicación involucrados[25].

3.2.1. Registro

El proceso de registro en WebAuthn implica la creación de nuevas credenciales de clave pública que se utilizarán para autenticar al usuario en el futuro. En la figura 3.1 (obtenida de [29]), detallaremos el flujo de comunicación y los parámetros relevantes utilizados durante el registro.

Flujo de Comunicación
El proceso de registro sigue un flujo de comunicación entre el cliente, el servidor y el autenticador:

1. Solicitud de Registro: El usuario inicia el proceso de registro indicando su intención de utilizar un autenticador como método de autenticación en su cuenta.

2. Envío de Desafío al Cliente: El servidor genera un desafío aleatorio y lo envía al cliente, junto con otros datos necesarios para el registro.

3. Generación de Credenciales: El cliente utiliza la API de WebAuthn para enviar el desafío y otros datos al autenticador. El autenticador genera un nuevo par de claves y crea una credencial asociada con el usuario y el sitio web.

4. Envío de Credenciales al Servidor: El cliente envía la información de la credencial al servidor para su verificación y almacenamiento.

5. Verificación de Credenciales: El servidor verifica la información de la credencial recibida del cliente y la almacena asociada con la cuenta de usuario.

6. Confirmación al Cliente: Una vez que el servidor ha verificado y almacenado con éxito las credenciales, se envía una confirmación al cliente para indicar que el registro ha sido exitoso.

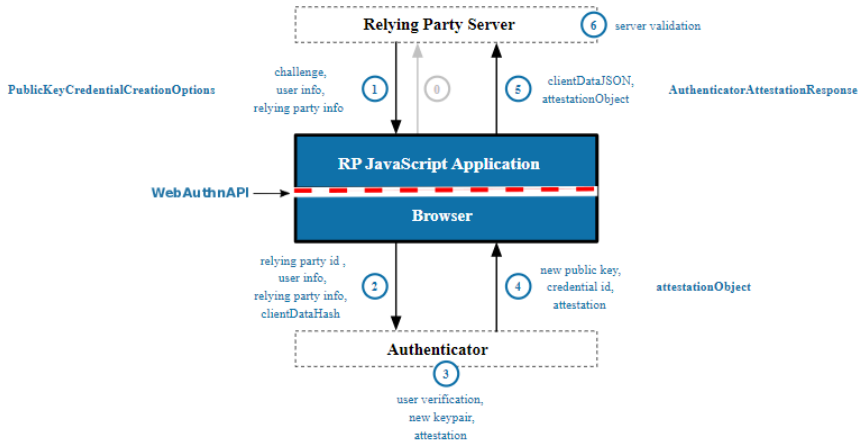

Figura 3.1: Registration Flow

Parámetros Relevantes

Durante el proceso de registro, se utilizan varios parámetros relevantes para generar y transmitir las credenciales al servidor[26]:

- challenge: Una cadena aleatoria generada por el servidor y enviada al cliente como parte del desafío de registro. Este desafío ayuda a prevenir ataques de repetición y garantiza que el registro sea en tiempo real.
- rp: Información sobre el origen (sitio web) que solicita el registro, incluyendo el nombre, el icono y el ID. Esta información se asocia con el par de claves y limita su alcance al dominio utilizado.
- user: Información adicional asociada con la cuenta de usuario, como el nombre de usuario o un identificador único. Esto puede ser útil para aplicaciones que desean asociar las credenciales con información de usuario específica.
- pubKeyCredParams: Lista de algoritmos de clave pública admitidos por el servidor para la generación del par de claves. Esto incluye algoritmos como RS256, PS256 o ECDSA, entre otros.
- authenticatorSelection: Preferencias sobre el tipo de autenticador que se utilizará, como si debe ser un autenticador integrado en la plataforma o un token físico externo.
- attestation: Nivel de confianza para la atestación de las credenciales. Esto puede incluir información sobre la procedencia y las capacidades del autenticador, como certificados de fábrica y firmas de certificación.

3.2.2. Autenticación

El proceso de autenticación en WebAuthn implica la verificación de la identidad del usuario utilizando las credenciales previamente registradas. En la figura 3.2 (obtenida de [29]),

detallaremos el flujo de comunicación y los parámetros relevantes utilizados durante la autenticación.

Flujo de Comunicación

El proceso de autenticación sigue un flujo de comunicación similar al registro, pero en este caso, el usuario ya tiene una credencial registrada y está demostrando su identidad para acceder a su cuenta.

1. Solicitud de Autenticación: El usuario inicia el proceso de autenticación solicitando acceso a su cuenta en el servidor.
2. Envío de Desafío al Cliente: El servidor genera un desafío aleatorio y lo envía al cliente.
3. Firma del Desafío: El cliente utiliza la clave privada asociada con la credencial registrada para firmar el desafío y generar una afirmación de autenticación.
4. Envío de la Afirmación al Servidor: El cliente envía la afirmación de autenticación al servidor.
5. Verificación de la Firma: El servidor verifica la firma utilizando la clave pública asociada con la credencial registrada. Si la verificación es exitosa y coincide con el desafío original, el usuario se considera autenticado y se le otorga acceso a su cuenta.

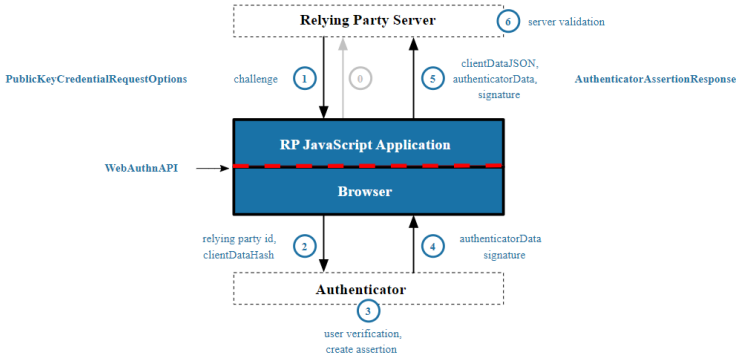

Figura 3.2: Authentication Flow

Parámetros Relevantes

Durante el proceso de autenticación, se utilizan varios parámetros relevantes para generar y verificar la afirmación de autenticación:

- challenge: Una cadena aleatoria generada por el servidor y enviada al cliente como parte del desafío de autenticación. El autenticador firma este desafío junto con otros datos para demostrar su identidad.
- allowCredentials: Una lista opcional de identificadores de credenciales que el servidor permite utilizar para la autenticación. El autenticador buscará coincidencias entre estas credenciales y las que posee.

- authenticatorData: Datos proporcionados por el autenticador que incluyen información sobre la autenticación, como el contador de firmas y otros flags.
- clientDataJSON: Datos transmitidos desde el navegador al autenticador, incluyendo el origen del sitio web, el tipo de solicitud y el desafío de autenticación.
- signature: La firma generada por el autenticador utilizando su clave privada sobre la concatenación de la información del autenticador y los datos del cliente.
- userHandle: Un identificador único asociado con la cuenta de usuario, útil para la autenticación sin necesidad de usuario ni contraseña en casos de claves residentes.

Verificación en el Servidor
En el servidor, se verifica la firma recibida del cliente utilizando la clave pública asociada con la credencial registrada. Si la verificación es exitosa y coincide con el desafío original, se considera que el usuario está autenticado y se le concede acceso a su cuenta.

3.3. Posibles Escenarios WebAuthn

3.3.1. WebAuthn como Segundo Factor (2FA)

En este escenario, representado en la figura 3.3 (obtenida de [30]), WebAuthn se utiliza como una capa adicional de seguridad, conocida como segundo factor de autenticación (2FA), junto con otro método de autenticación, como contraseñas. Después de que el usuario ingresa su contraseña, se le solicita que presente una credencial WebAuthn, como una llave de seguridad o un dispositivo biométrico, para completar el proceso de autenticación. Esto aumenta significativamente la seguridad al requerir que el usuario presente algo que tiene (la credencial física) junto con algo que sabe (la contraseña), lo que hace que sea más difícil para los atacantes comprometer las cuentas.[28]

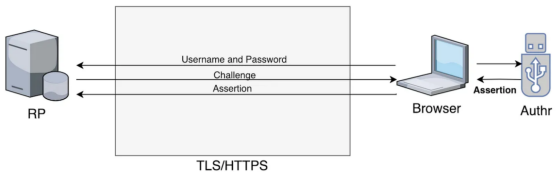

Figura 3.3: WebAuthn como segundo factor de autenticación (2F)

3.3.2. WebAuthn sin envío de contraseñas

En este escenario, representado en la figura 3.4 (obtenida de [30]), WebAuthn elimina completamente la necesidad de contraseñas en el proceso de autenticación. En lugar de ingresar una contraseña, el usuario simplemente presenta una credencial WebAuthn, como una llave de seguridad o un dispositivo biométrico, para demostrar su identidad. Esto elimina el riesgo asociado con el robo o la interceptación de contraseñas, ya que el proceso de

autenticación se basa únicamente en la posesión física del dispositivo de autenticación y no en el conocimiento de una contraseña.

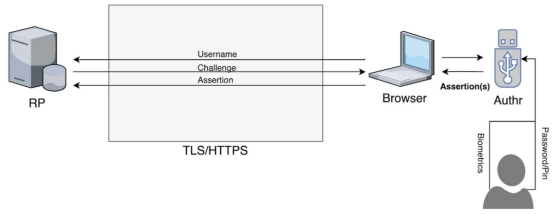

Figura 3.4: WebAuthn sin contraseña

3.3.3. WebAuthn sin usuarios ni contraseñas

En este escenario más avanzado, representado en la figura 3.5 (obtenida de [30]), WebAuthn elimina por completo la necesidad de nombres de usuario y contraseñas. En su lugar, se utilizan credenciales asociadas directamente con el dispositivo de autenticación del usuario. Esto se logra gracias a las claves residentes, que permiten la autenticación sin la necesidad de conocimiento previo de las claves. El usuario simplemente elige una de las credenciales residentes disponibles en el dispositivo de autenticación para completar la autenticación. Este enfoque mejora aún más la seguridad al eliminar por completo la exposición de información secreta.

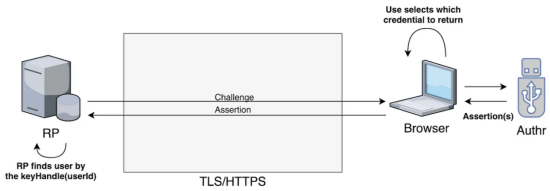

Figura 3.5: WebAuthn sin usuario ni contraseña

3.3.4. Pérdida de Credenciales

En caso de pérdida de una credencial WebAuthn, el usuario debe informar al servidor para que pueda tomar las medidas necesarias. Esto incluye eliminar la credencial perdida de la base de datos del servidor y proporcionar al usuario la opción de registrar una nueva credencial. Además, cualquier intento de autenticación con la credencial perdida debe ser rechazado para proteger la seguridad de la cuenta.

3.3.5. Anulación Credenciales (Inactividad)

Si una credencial permanece inactiva durante un período prolongado o si hay motivos para creer que la credencial puede estar comprometida, el servidor puede optar por anular

la credencial. Esto implica eliminar la credencial de la base de datos del servidor y rechazar cualquier intento de autenticación con esa credencial. Esta medida ayuda a mantener la seguridad de la cuenta al prevenir el acceso no autorizado.

3.3.6. Elimina Credenciales de Autenticador

Los usuarios también pueden optar por eliminar manualmente las credenciales almacenadas en sus dispositivos de autenticación. Esto puede ser necesario en caso de pérdida o robo del dispositivo, o si el usuario desea cambiar a un nuevo dispositivo. Al eliminar una credencial del autenticador, se garantiza que esa credencial ya no pueda utilizarse para autenticarse, lo que contribuye a proteger la seguridad de la cuenta.

3.4. Ventajas y Desventajas

Ventajas:

- Eliminación de Contraseñas Débiles y Reutilización: La eliminación de contraseñas débiles y su reutilización es una de las mayores ventajas de WebAuthn. Al utilizar autenticación basada en hardware, se supera la vulnerabilidad inherente de las contraseñas tradicionales.
- Confianza en el Usuario: Al utilizar WebAuthn, los usuarios no necesitan confiar en que el servidor maneje sus contraseñas de manera segura. La responsabilidad de la autenticación recae en el autenticador del usuario, lo que aumenta la confianza en el sistema.
- Seguridad Mejorada: WebAuthn ofrece una seguridad mejorada al eliminar vulnerabilidades como el phishing y los ataques de intermediarios. Al utilizar criptografía de clave pública y autenticación basada en hardware, se reduce drásticamente la posibilidad de comprometer la seguridad de la cuenta.
- Facilidad de Desarrollo: Para los desarrolladores, WebAuthn simplifica la implementación de la autenticación en entornos web. Al integrar un estándar establecido, se reduce la carga de trabajo de diseño y desarrollo de nuevos sistemas de autenticación.
- Flexibilidad de Dispositivos: Los usuarios tienen la flexibilidad de utilizar una variedad de dispositivos de autenticación compatibles con WebAuthn, lo que les permite elegir la opción que mejor se adapte a sus necesidades y preferencias.
- Compatibilidad con Navegadores: La creciente compatibilidad de WebAuthn con los principales navegadores web garantiza una experiencia de usuario uniforme y accesible para la mayoría de los usuarios de Internet.

Desventajas:

- Necesidad de Dispositivos de Hardware: Una de las principales desventajas de WebAuthn es la necesidad de dispositivos de hardware compatibles para la autenticación. Esto

puede resultar inconveniente para algunos usuarios que no tienen acceso a estos dispositivos o que prefieren métodos de autenticación más simples.

- Curva de Aprendizaje: La transición a WebAuthn puede requerir tiempo y esfuerzo para que los usuarios se familiaricen con el nuevo método de autenticación. Esto puede ser especialmente cierto para aquellos menos familiarizados con la tecnología.
- Dependencia de la Conectividad: WebAuthn depende de la conectividad a Internet y la disponibilidad del servicio de autenticación en línea. La falta de conexión a Internet o problemas de red pueden dificultar la autenticación del usuario.
- Posibles Problemas de Interoperabilidad: A medida que WebAuthn continúa evolucionando y siendo adoptado por una variedad de servicios y plataformas, pueden surgir problemas de interoperabilidad entre diferentes implementaciones, lo que podría dificultar la experiencia del usuario en algunos casos.

Capítulo 4

Fase de Investigación y Análisis

4.1. Análisis de la Arquitectura y Requisitos de SimpleSAMLphp

SimpleSAMLphp es un marco de autenticación y autorización basado en PHP que facilita la integración de servicios de autenticación en aplicaciones web. Su arquitectura modular proporciona flexibilidad para adaptarse a diversas necesidades de autenticación[31].

4.1.1. Componentes y Funcionalidades Clave

Componentes Clave:

- SAML: Implementa el protocolo SAML para permitir la autenticación basada en afirmaciones.
- OAuth: Admite el protocolo OAuth para la autorización de aplicaciones de terceros.
- OpenID Connect: Facilita la integración con servicios de autenticación basados en OpenID Connect.
- LDAP: Permite la autenticación utilizando servidores LDAP para la autenticación contra directorios de usuarios.
- Base de Datos: SimpleSAMLphp es compatible con una variedad de bases de datos relacionales y NoSQL para almacenar información de configuración y sesiones de usuario.
- Administración: Proporciona una interfaz de usuario para administrar la configuración del sistema, incluidos metadatos de federación, configuraciones de autenticación y autorización, y gestión de usuarios.
- Autenticación: Ofrece una interfaz de usuario para que los usuarios finales autentiquen sus identidades, interactuando con los diferentes métodos de autenticación disponibles.

Funcionalidades Clave:

- Federación de Identidad: SimpleSAMLphp permite establecer relaciones de confianza entre diferentes proveedores de identidad y servicios de autenticación, facilitando la federación de identidad en entornos distribuidos.
- SSO (Single Sign-On): Permite a los usuarios autenticarse una vez y acceder a múltiples servicios protegidos sin tener que volver a autenticarse, mejorando la experiencia del usuario y simplificando la gestión de contraseñas.
- Adaptabilidad y Personalización: SimpleSAMLphp es altamente adaptable y personalizable, lo que permite a los administradores y desarrolladores personalizar la interfaz de usuario, implementar nuevos módulos de autenticación y ajustar la configuración según las necesidades específicas del entorno.
- Seguridad: Ofrece diversas medidas de seguridad, como la gestión de claves y certificados, la protección contra ataques de fuerza bruta y la validación de mensajes firmados para garantizar la autenticidad e integridad de los datos.

4.1.2. Requisitos para la Implementación de FIDO y PrivacyIDEA

Requisitos para la Implementación de FIDO:

- Soporte: SimpleSAMLphp debe ser capaz de integrarse con FIDO2 para admitir la autenticación basada en llaves públicas y criptografía de alta seguridad.
- Compatibilidad con Navegadores: SimpleSAMLphp debe ser compatible con los navegadores web modernos que admiten FIDO2, lo que permite a los usuarios autenticarse utilizando dispositivos compatibles con FIDO2, como llaves de seguridad USB y dispositivos biométricos.
- Integración con PrivacyIDEA: SimpleSAMLphp debe integrarse con PrivacyIDEA para proporcionar un backend seguro y escalable para el registro y la autenticación de dispositivos FIDO2, garantizando la privacidad y la confidencialidad de los datos de autenticación.
- Seguridad y Privacidad: Es fundamental que SimpleSAMLphp implemente medidas de seguridad robustas para proteger las comunicaciones entre el cliente y el servidor durante el proceso de autenticación FIDO2, así como para garantizar la privacidad de los datos de autenticación almacenados en PrivacyIDEA.

Requisitos para la Implementación de PrivacyIDEA:

- Almacenamiento Seguro de Datos: PrivacyIDEA debe ser capaz de almacenar de forma segura la información de autenticación, incluidas las credenciales FIDO2, utilizando técnicas de cifrado y hashing robustas para proteger los datos confidenciales.
- Integración con SimpleSAMLphp: PrivacyIDEA debe integrarse estrechamente con SimpleSAMLphp para proporcionar un backend de autenticación confiable y escalable que admita múltiples métodos de autenticación, incluida la autenticación FIDO2.

- Escalabilidad y Disponibilidad: PrivacyIDEA debe ser capaz de escalar horizontalmente para manejar cargas de autenticación crecientes y garantizar la disponibilidad del servicio incluso en condiciones de alta demanda.
- Administración de Políticas de Autenticación: PrivacyIDEA debe permitir a los administradores definir y aplicar políticas de autenticación personalizadas, incluidos requisitos de complejidad de contraseña, períodos de expiración y factores de autenticación múltiples.
- Auditoría y Registro: PrivacyIDEA debe proporcionar funcionalidades de auditoría y registro detalladas para rastrear y registrar todas las actividades de autenticación, incluidos intentos exitosos y fallidos, garantizando la trazabilidad y la conformidad con los requisitos de seguridad.

Capítulo 5

Fase de Configuración y Despliegue

5.1. Instalación y Configuración de SimpleSAMLphp

5.1.1. Pasos Detallados para la Instalación

Preparación del Entorno:
Actualizo el sistema y agrega el repositorio de PHP PPA para obtener las versiones deseadas de PHP.

```
$ sudo apt update
$ sudo add-apt-repository ppa:ondrej/php
```

Instalación de Apache y PHP:
Instalo Apache y las versiones específicas de PHP necesarias para SimpleSAMLphp.

```
$ sudo apt install apache2
$ sudo apt install php7.2 php7.1-common php7.2-curl php7.1-ldap php7
↪ .1-mysql php7.1-pgsql php7.1-memcache php7.1-redis php7.1-json
↪ php7.1-mbstring php7.1-sqlite3 php7.2-xml
```

Instalación de Composer:
Descargo e instalo Composer para administrar las dependencias de PHP.

```
$ php -r "copy('https://getcomposer.org/installer', 'composer-setup.
↪ php');"
$ php -r "if (hash_file('sha384', 'composer-setup.php') === '
↪ dac665fdc30fdd8ec78b38b9800061b4150413ff2e3b6f88543c636f7cd84f6db9
↪ ') { echo 'Installer verified'; } else { echo 'Installer corrupt';
↪  unlink('composer-setup.php'); } echo PHP_EOL;"
$ php ./composer-setup.php --version=2.2.23
$ sudo cp composer.phar /usr/local/bin/composer
```

Descarga y Extracción de SimpleSAMLphp: Descargo y extraigo SimpleSAMLphp en el directorio deseado /var/simplesamlphp.

```
$ tar xzf simplesamlphp-1.19.9.tar.gz
```

```
$ mv simplesamlphp-1.19.9 /var/simplesamlphp
```

Configuración de Apache:
Configuro Apache para que sirva SimpleSAMLphp.
Crea un archivo de configuración para SimpleSAMLphp en /etc/apache2/sites-available/simplesamlphp.conf y agrega la configuración necesaria.
Habilita el sitio y el módulo SSL en Apache.

```
$ sudo nano /etc/apache2/sites-available/simplesamlphp.conf
$ sudo a2ensite simplesamlphp.conf
$ sudo a2enmod ssl
```

Generación de Certificados SSL (Opcional):
Para poder habilitar HTTPS, genera y configura los certificados SSL.

```
$ openssl genrsa -des3 -out /etc/ssl/private/apache.key 2048
$ openssl req -x509 -nodes -days 365 -newkey rsa:2048 -keyout /etc/
↪ ssl/private/apache.key -out /etc/ssl/certs/apache.crt
```

Reinicio de Apache:
Reinicio Apache para aplicar los cambios.

```
$ sudo systemctl reload apache2
```

5.1.2. Configuración de Parámetros Esenciales

Configuración de los certificados:
Es necesario tener configurados correctamente los certificados SSL/TLS en los servidores.

```
$ nano /var/simplesamlphp/cert/server.key
$ nano /var/simplesamlphp/cert/server.pub
```

Configuración del Almacenamiento de Datos:
Configuro SimpleSAMLphp para utilizar un sistema de almacenamiento de datos adecuado.

```
$ nano /var/simplesamlphp/config/config.php
```

Configuración de Autenticación:
Configuro los módulos de autenticación de SimpleSAMLphp.

```
$ nano /var/simplesamlphp/config/authsources.php
```

Tanto la configuración del Service Provider como la del Identity Provider es la misma, pero cambiando algunos parámetros. Por ello se configuran ambos con los mismos parámetros y luego se configuran específicamente algunos parámetros.

Configuración del archivo config.php:
Establezco la baseurlpath opción de configuración.

```
1    'baseurlpath' => 'simplesaml/',
```

Establezco una contraseña de administrador. Esto es necesario para acceder a algunas de las páginas de la interfaz web de instalación de SimpleSAMLphp. Aquí también se pueden

utilizar contraseñas hash.

```
    'auth.adminpassword' => '63AU9C',
```

Establecer una sal secreta. Esta debería ser una cadena aleatoria. Algunas partes de SimpleSAMLphp necesitan esta sal para generar hashes criptográficamente seguros.

```
    'secretsalt' => '5k79paffgv47218nq5pd6e6kcy4s7q33',
```

El siguiente comando genera una cadena aleatoria:

```
$ tr -c -d '0123456789abcdefghijklmnopqrstuvwxyz' </dev/urandom | dd
↪  bs=32 count=1 2>/dev/null;echo
```

Establecer información de contacto técnico. Esta información estará disponible en los metadatos generados. La dirección de correo electrónico también se utilizará para recibir informes de errores enviados automáticamente por SimpleSAMLphp.

```
    'technicalcontact_name' => 'Antonio Jos Muriel Glvez',
    'technicalcontact_email' => 'antoniojose.muriel@alu.uhu.es',
```

Si utiliza SimpleSAMLphp en un país donde el inglés no está muy extendido, en este caso cambio el idioma predeterminado del inglés al español:

```
    'language.default' => 'es',
```

Establece la zona horaria

```
    'timezone' => 'Europe/Madrid',
```

Configuracion del Service Provider (SP)

El SP se configura mediante una entrada en config/authsources.php. Este es un mínimo authsources.php para un SP:

```
'default-sp' => [
    'saml:SP',
    'privatekey' => 'server.pem',
    'certificate' => 'server.crt',
    'entityID' => 'https://192.168.106.142/simplesaml/module.php/saml/sp/metadata.php/
    ↪ default-sp',
    'idp' => null,
]
```

El proveedor de servicios que está configurando necesita conocer los proveedores de identidad a los que se conectará. Esto se configura mediante metadatos almacenados en metadata/saml20-idp-remote.php.

Configuracion del Identity Provider (IdP)

Lo primero que se debe hacer es habilitar la funcionalidad del proveedor de identidad. Esto se hace editando config/config.php . La opción enable.saml20-idp controla si la compatibilidad con SAML 2.0 IdP está habilitada.

```
    'enable.saml20-idp' => true,
```

Para poder cargar el módulo de privacyIdea es necesario añadirlo a los módulos

```
$ composer require privacyidea/simplesamlphp-module-privacyidea
```

El siguiente paso es configurar la forma en que los usuarios se autentican en su IdP. Varios módulos en el modules/ directorio proporcionan métodos para autenticar a sus usuarios.

```
    'module.enable' => [
        'exampleauth' => true,
        'core' => true,
        'saml' => true,
        'privacyidea' => true,
        'sqlauth' => true,
        'consent' => true,
    ],
```

El IdP SAML 2.0 se configura mediante los metadatos almacenados en metadata/saml20-idp-hosted.php.
El proveedor de identidad que está configurando necesita conocer los proveedores de servicios a los que se conectará. Esto se configura mediante metadatos almacenados en metadata/saml20-sp-remote.php.

5.2. Integración de PrivacyIDEA y Configuración del Servidor

5.2.1. Configuración de PrivacyIDEA en el Entorno de SimpleSAMLphp

Comienzo instalando PrivacyIDEA en el entorno. Para ello instalo PrivacyIDEA en un servidor separado.
Para poder instalar PrivacyIDEA es necesario agregar el repositorio jammy para la versión de ubuntu 22.04LTS

```
$ add-apt-repository http://lancelot.netknights.it/community/jammy/
↪ stable
```

Actualizo el sistema e instalacio privacidadIDEA 3 en el servidor web Apache2

```
$ apt update
$ apt install privacyidea-apache2
```

5.2.2. Ajustes de Seguridad y Personalización

Para configurar la seguridad inicial de PrivacyIDEA creo un administrador con el cual se puede acceder a la interfaz del servidor de PrivacyIDA en modo administrador. El comando utilizado es pi-manage admin add, que se utiliza para agregar un nuevo administrador a PrivacyIDEA

```
$ pi-manage admin add admin -e admin@localhost
```

5.3. Políticas Para Usuarios

5.3.1. Políticas de Administración

En las políticas de administración se pueden configurar hasta 100 permisos para poder tener distintos administradores con distintos privilegios. Voy a explicar algunas de las políticas las cuales pueden ser más interesantes para los distintos administradores.

- Inscribirse: Esta política permite controlar qué tipos de tokens pueden inscribirse en el sistema. Es crucial para garantizar que solo se utilicen los tipos de tokens permitidos y que cumplan con los requisitos de seguridad de la organización.
- Desactivar/Revocar: Estas políticas permiten al administrador desactivar o revocar tokens. Esto es esencial en caso de pérdida o robo de un dispositivo de autenticación para evitar accesos no autorizados.
- Colocar: La política Çolocar"permite al administrador establecer propiedades adicionales del token, como descripción o período de validez. Esto puede ser útil para administrar y organizar mejor los tokens dentro del sistema.
- Configwrite/Configread: Estas políticas permiten al administrador escribir o leer la configuración del sistema. Esto es fundamental para ajustar la configuración de PrivacyIDEA según las necesidades específicas de la organización y para realizar ajustes de seguridad.
- Registro de auditoría/Auditlog_download: Estas políticas permiten al administrador ver y descargar el registro de auditoría del sistema. Es esencial para monitorear las actividades realizadas en el sistema, auditar el acceso y cumplir con los requisitos de cumplimiento normativo.
- Documentación del sistema: Esta política permite exportar una documentación completa del sistema. Esto puede ser útil para mantener registros detallados de la configuración y la configuración del sistema, así como para proporcionar documentación para auditorías y fines de cumplimiento normativo.
- User_management_read/User_management_write: Estas políticas permiten al administrador leer o escribir en la gestión de usuarios. Esto es crucial para administrar las cuentas de usuario, incluida la creación, modificación y eliminación de usuarios, y garantizar que el acceso al sistema esté bien administrado.
- Tokens_enrollment_read/Tokens_enrollment_write: Estas políticas permiten al administrador leer o escribir en la inscripción de tokens. Es esencial para gestionar el proceso de inscripción de dispositivos de autenticación y garantizar que solo se inscriban tokens autorizados.

5.3.2. Políticas de Usuario

PrivacyIDEA proporciona un conjunto diverso de políticas que permiten a los administradores de sistemas ejercer un control preciso sobre la configuración y operación de los tokens de autenticación. Estas políticas abarcan aspectos clave como la inscripción, asignación, desactivación, eliminación y resincronización de tokens, brindando a los usuarios finales la flexibilidad necesaria para gestionar sus propios dispositivos de autenticación de manera segura y eficiente.
A continuación voy a exponer cuales son las políticas que he puesto para tener organizados a los usuarios y administradores.

Políticas de interfaz de usuario web:
En esta política solo he puesto las necesarias para que tenga una interfaz mínimamente personalizada, pero se pueden añadir templates personalizados para darle una apariencia totalmente diferente.

- hide_welcome_info: El administrador ya no verá el cuadro de diálogo de bienvenida.
- login_text: Universidad de Huelva. Un texto alternativo para mostrar en el cuadro de diálogo de inicio de sesión de WebUI en lugar de Ïnicio de sesión".

Políticas de Autorización:

- add_resolver_in_response: En caso de una autenticación exitosa, el almacen de usuario y el dominio se agregarán en la rama de detalle de la respuesta de autenticación.
- add_user_in_response: En caso de una autenticación exitosa, los datos del usuario se agregarán en la rama de detalle de la respuesta de autenticación.
- application_tokentype: Permite que la aplicación elija qué tipos de token se deben usar para la autenticación. La aplicación puede establecer el parámetro 'tipo' en la solicitud. Funciona con validate / check, validate / samlcheck y validate / triggerchallenge

Políticas de Autenticación:
Para la autenticación he aplicado dos políticas, una para las contraseñas de los usuarios y otra para los token de los usuario.

Políticas para los Token:

- otppin: Utilice el PIN del token. En este caso junto al token hay que poner el pin que se introdujo con el pin.
- passthru: El usuario en este ámbito se autenticará contra el almacén de usuarios
- u2f_facets: Esta es una lista de nombres de host FQDN que confían en los tokens U2F registrados.

Políticas para las Password:

- otppin: Utilice la contraseña del almacén de usuarios.

textbfPolíticas de usuario:

- enrollHOTP: El usuario puede inscribir un token HOTP.
- enrollSPASS: El usuario puede inscribir un token SPASS.
- enrollU2F: El usuario puede inscribir un token U2F.
- enrollYUBIKEY: El usuario puede inscribir un token YUBIKEY.
- enrollpin: El usuario puede establecer el PIN OTP durante la inscripción.

Capítulo 6

Fase de Pruebas y Evaluación

6.1. Diseño y Definición de Tokens

Con el fin de adaptarse a las diversas necesidades de autenticación, PrivacyIDEA ofrece una amplia gama de tokens, cada uno diseñado para satisfacer requisitos específicos de seguridad y comodidad. Estos tokens van desde métodos tradicionales de contraseña hasta tecnologías de autenticación de última generación basadas en hardware y software.

En esta sección, exploraremos en detalle los diferentes tipos de tokens disponibles en PrivacyIDEA, destacando sus características, casos de uso y consideraciones de seguridad. Desde tokens de contraseña de un solo uso hasta dispositivos de autenticación basados en hardware como Yubikeys y tokens de aplicación específica, PrivacyIDEA proporciona una solución versátil y adaptable para garantizar la autenticación segura en diversos entornos y escenarios de uso.

A través de este estudio, no solo buscaremos comprender las fortalezas y limitaciones de FIDO en relación con otros tipos de tokens, sino también proporcionar una visión integral sobre cómo las organizaciones pueden elegir la solución de autenticación más adecuada para sus necesidades específicas en un mundo digital cada vez más complejo y dinámico. Y a continuación voy a mostrar cuales son los distintos tipos de autenticación que tiene privacyIDEA:

- Four Eyes: Un meta token que se puede utilizar para crear una Regla de Dos Hombres.
- Certificate Token: Un token que representa un certificado de cliente.
- Day Password Token: Un token de contraseña diaria basado en el tiempo que se puede utilizar varias veces.
- Email: Un token que envía el valor OTP a la dirección de correo electrónico del usuario.
- HOTP Token: Tokens de contraseña de un solo uso basados en eventos según RFC4226.

- Indexed Secret Token: Un token de respuesta de desafío que solicita al usuario posiciones aleatorias de una cadena secreta.
- Daplug: Un token OTP de hardware similar al Yubikey.
- mOTP Token: Tokens de contraseña de un solo uso basados en el tiempo para teléfonos móviles basados en un algoritmo público.
- OCRA: Un token básico de desafío de respuesta de OATH.
- Paper Token (PPR): Tokens de contraseña de un solo uso basados en eventos que proporcionan una lista de contraseñas de un solo uso en una hoja de papel.
- Push Token: Un token de respuesta de desafío que envía un desafío al teléfono inteligente del usuario y el usuario simplemente acepta la solicitud para iniciar sesión.
- Password Token: Un token de contraseña utilizado para escenarios de pérdida de token.
- Application Specific Password Token: Un token de contraseña específico de la aplicación basado en el Token de Contraseña. Se puede utilizar para proporcionar una contraseña estática para servicios o aplicaciones específicas.
- Questionnaire Token: Un token que contiene una lista de preguntas respondidas. Durante la autenticación, se presenta una pregunta aleatoria como desafío de la lista de preguntas respondidas. El usuario debe dar la respuesta correcta.
- Registration: Un tipo de token especial utilizado para escenarios de inscripción.
- RADIUS: Un token virtual que reenvía la solicitud de autenticación a un servidor RADIUS.
- Remote: Un token virtual que reenvía la solicitud de autenticación a otro servidor privacyIDEA.
- SMS Token: Un token que envía el valor OTP al teléfono móvil del usuario.
- Spass (Simple Pass Token): El token de contraseña simple. Un token que no tiene componente OTP y solo consiste en el PIN OTP o (si se establece otppin=userstore) de la contraseña de la tienda de usuarios.
- SSH Keys: Una clave pública SSH que se puede administrar y utilizar junto con el concepto de Máquinas.
- TiQR: Un token de teléfono inteligente que se puede utilizar para iniciar sesión simplemente escaneando un código QR.
- TOTP: Tokens de contraseña de un solo uso basados en el tiempo según RFC6238.

- U2F: Un dispositivo U2F según lo especificado por la Alianza FIDO. Este es un dispositivo USB que se utiliza para la autenticación de respuesta de desafío.
- VASCO: El token propietario de VASCO.
- WebAuthn: El token WebAuthn o FIDO2 que puede usar varios mecanismos diferentes como tokens USB o TPM para autenticar mediante criptografía de clave pública.
- Yubikey: Un hardware Yubikey inicializado en el modo AES, que se autentica contra privacyIDEA.
- Yubico: Un hardware Yubikey que se autentica contra el servicio en la nube de Yubico.

Para mi TFG, he propuesto una solución innovadora basada en las ventajas de FIDO para mejorar la autenticación en la Universidad de Huelva. Considerando la amplia gama de tokens disponibles en PrivacyIDEA, mi enfoque se centra en aprovechar las características distintivas de FIDO para fortalecer la seguridad y la experiencia del usuario en el entorno universitario.

Al integrar la tecnología FIDO en el sistema de autenticación de la Universidad de Huelva, se abre la puerta a una autenticación más sólida y eficiente. La adopción de tokens FIDO ofrece beneficios significativos, como la autenticación multifactorial sin contraseñas, la resistencia al phishing y el soporte para una amplia variedad de dispositivos, desde llaves USB hasta teléfonos inteligentes.

Al implementar esta solución, se promueve una experiencia de usuario más fluida y segura para estudiantes, profesores y personal administrativo. Los usuarios pueden autenticarse de manera conveniente utilizando dispositivos compatibles con FIDO, lo que reduce la fricción en el proceso de inicio de sesión y aumenta la confianza en la seguridad de sus cuentas.

Además, al aprovechar la flexibilidad y la escalabilidad de PrivacyIDEA, la solución propuesta puede adaptarse fácilmente a las necesidades específicas de la Universidad de Huelva, brindando un marco sólido para la gestión centralizada de la autenticación y la protección de los recursos digitales de la institución.

6.2. Diseño y Casos de Uso

6.2.1. Diseño

El diseño de la distribución de servidores es un aspecto crucial en la implementación de un sistema de autenticación robusto y seguro. En este contexto, se busca diseñar una arquitectura que permita gestionar de manera eficiente las solicitudes de autenticación de los usuarios, garantizando al mismo tiempo la integridad y confidencialidad de los datos. Para ello, se ha propuesto una distribución compuesta por tres componentes principales, como se muestra en la figura 6.1: El servidor SP (SimpleSAMLphp), el servidor IdP (SimpleSAMLphp)

y el servidor PrivacyIDEA. Cada uno de estos servidores desempeña un papel específico en el proceso de autenticación, desde la solicitud inicial hasta la verificación de la identidad del usuario y la gestión de los tokens asociados. En este contexto, el diseño de la distribución de servidores debe tener en cuenta aspectos como la accesibilidad, la seguridad y la escalabilidad, con el objetivo de proporcionar una experiencia de autenticación fluida y segura para los usuarios finales.

1. Servidor SP (SimpleSAMLphp):
   - Este servidor estará dedicado a solicitar la autenticación de los usuarios y a obtener los datos del usuario.
   - Se recomienda alojar este servidor en una ubicación accesible desde Internet para que los usuarios puedan iniciar sesión de forma remota.
   - Puede estar configurado con una dirección URL pública para que los usuarios puedan acceder fácilmente al proceso de autenticación.
2. Servidor IdP (SimpleSAMLphp):
   - Este servidor actuará como el proveedor de identidades y será responsable de verificar los datos para la autenticación del usuario.
   - Se conectará con el servidor SP para recibir solicitudes de autenticación y enviar los datos del usuario verificados.
   - Se recomienda alojar este servidor en una ubicación segura y de confianza, preferiblemente en la misma red privada que PrivacyIDEA para minimizar la latencia y mejorar la seguridad de la comunicación entre ambos servidores.
3. Servidor PrivacyIDEA:
   - Será utilizado por el IdP para autenticaciones de primer y segundo factor.
   - Se conectará con una base de datos para almacenar la información de los usuarios y sus tokens. Esta base de datos está almacenada en el IdP.
   - Es fundamental que este servidor esté protegido adecuadamente, ya que contendrá datos sensibles de autenticación de los usuarios.

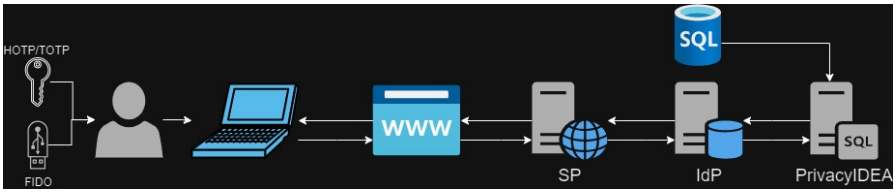

Figura 6.1: Distribución

6.2.2. Casos de Uso

Los casos de uso son una herramienta fundamental en el diseño y la planificación de sistemas de software, ya que describen cómo interactúan los usuarios con el sistema para lograr ciertos objetivos. En el contexto de este trabajo, los casos de uso son una parte esencial para comprender y definir los diferentes escenarios de autenticación que los usuarios experimentarán al interactuar con el sistema propuesto. A través de una cuidadosa descripción de estos casos, se pueden identificar los requisitos clave del sistema, definir sus funcionalidades y validar su diseño. En esta sección, se presentan y analizan varios casos de uso relacionados con la autenticación en línea utilizando diferentes métodos y factores de autenticación. Cada caso de uso describe un escenario específico que abarca desde la autenticación inicial hasta el acceso seguro a servicios o aplicaciones en línea, brindando una visión detallada de cómo los usuarios interactúan con el sistema en diferentes contextos y condiciones.

Casos de Uso para Autenticación:

Caso de Uso 1: Autenticación de un Usuario con Contraseña Simple:
Este caso de uso describe el proceso de autenticación de un usuario utilizando una contraseña simple como primer factor de autenticación. La siguiente secuencia se corresponde con la figura 6.2:

1. El usuario accede a un servicio o aplicación en línea que requiere autenticación.
2. El Servicio Proveedor (SP) solicita al usuario sus credenciales de inicio de sesión.
3. El usuario ingresa su nombre de usuario y contraseña en el formulario de inicio de sesión del SP.
4. El SP envía las credenciales proporcionadas por el usuario al Proveedor de Identidad (IdP) para su verificación.
5. El IdP recibe las credenciales y verifica la identidad del usuario comparándolas con los datos almacenados en su base de datos de usuarios.
6. Si las credenciales son válidas, el IdP autentica con éxito al usuario y permite el acceso al servicio o aplicación solicitado.

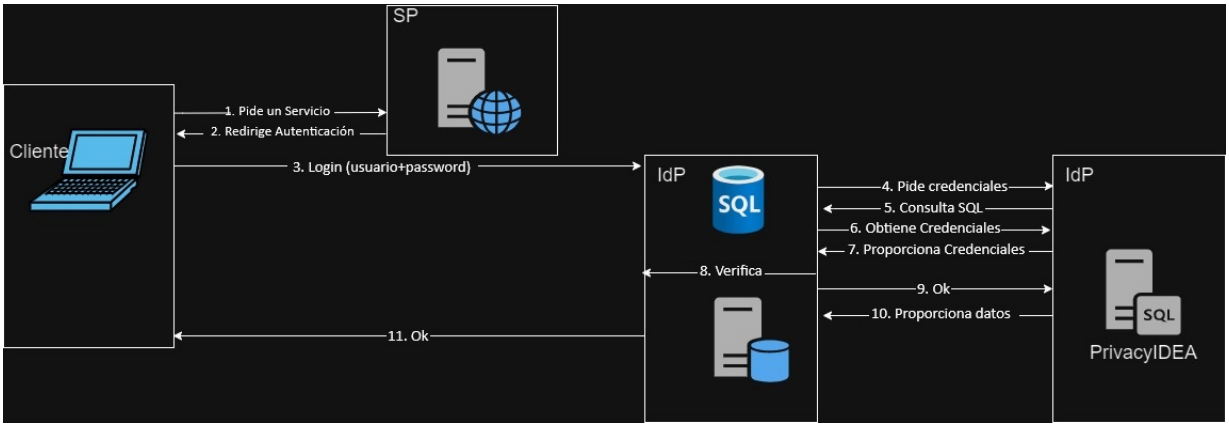

Figura 6.2: Diagrama de Flujo 1

Caso de Uso 2: Autenticación de un Usuario con Segundo Factor Google Authenticator:
Este caso de uso describe el proceso de autenticación de un usuario utilizando Google Authenticator como segundo factor después de la autenticación inicial con una contraseña simple.

1. Después de que el usuario haya completado con éxito el primer factor de autenticación utilizando una contraseña simple, el SP solicita un segundo factor de autenticación.

2. El IdP, actuando como intermediario, envía una solicitud a privacyIDEA para iniciar el proceso de autenticación de segundo factor utilizando Google Authenticator.

3. El usuario ingresa el código OTP actual generado por Google Authenticator en el formulario de autenticación del SP.

4. privacyIDEA verifica el código OTP proporcionado por el usuario para completar la autenticación de segundo factor.

5. Si la verificación del código OTP es exitosa, privacyIDEA informa al IdP, que a su vez notifica al SP de que el usuario ha sido autenticado con éxito.

6. El SP concede al usuario acceso al servicio o aplicación solicitado.

Caso de Uso 3: Autenticación de un Usuario con Segundo Factor FIDO:
Este caso de uso describe el proceso de autenticación de un usuario utilizando un segundo factor FIDO después de la autenticación inicial con una contraseña simple. La siguiente secuencia se corresponde con la figura 6.3:

1. Después de que el usuario haya completado con éxito el primer factor de autenticación utilizando una contraseña simple, el SP solicita un segundo factor de autenticación.

2. El IdP, que actúa como intermediario entre el SP y el sistema de gestión de identidades y autenticación (privacyIDEA), envía una solicitud al privacyIDEA para iniciar el proceso de autenticación de segundo factor.

3. PrivacyIDEA solicita al usuario que presente su token FIDO (por ejemplo, una llave de seguridad USB) para completar la autenticación de segundo factor.

4. El usuario inserta o activa su token FIDO y sigue el proceso de autenticación según las instrucciones proporcionadas por privacyIDEA.

5. privacyIDEA verifica la autenticación de segundo factor utilizando el token FIDO del usuario.

6. Si la autenticación de segundo factor es exitosa, privacyIDEA informa al IdP, que a su vez notifica al SP de que el usuario ha sido autenticado con éxito.

7. El SP concede al usuario acceso al servicio o aplicación solicitado.

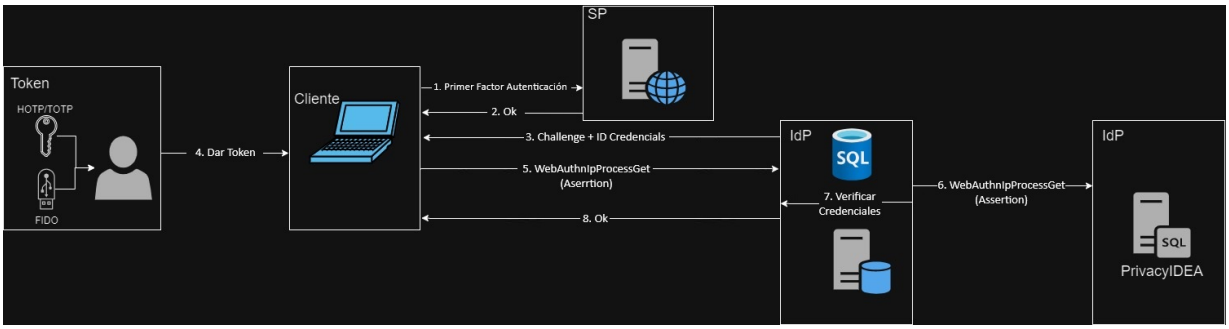

Figura 6.3: Diseño de Flujo 2 y 3

6.3. Ejemplos Prácticos

6.3.1. Registro de un Token

1.- Elegir el servicio de autenticación:

- Accede a la opción "Test authentication sources".
- Selecciona el servicio configurado con autenticación en el proveedor de identidad (IdP).

2.- Redirección al primer factor de autenticación del IdP:

- Después de seleccionar el servicio, serás redirigido al primer factor de autenticación del IdP. Esto incluye la introducción de credenciales como nombre de usuario y contraseña.
- En este se encuentra un enlace para configurar tokens. Haz clic en este enlace.

Figura 6.4: Login

3.- Redirección al servidor de PrivacyIDEA:

- Al hacer clic en el enlace, serás redirigido al servidor de PrivacyIDEA, donde necesitarás autenticarte para acceder a los tokens.
- Una vez en el servidor de PrivacyIDEA, autentícate utilizando las credenciales adecuadas.

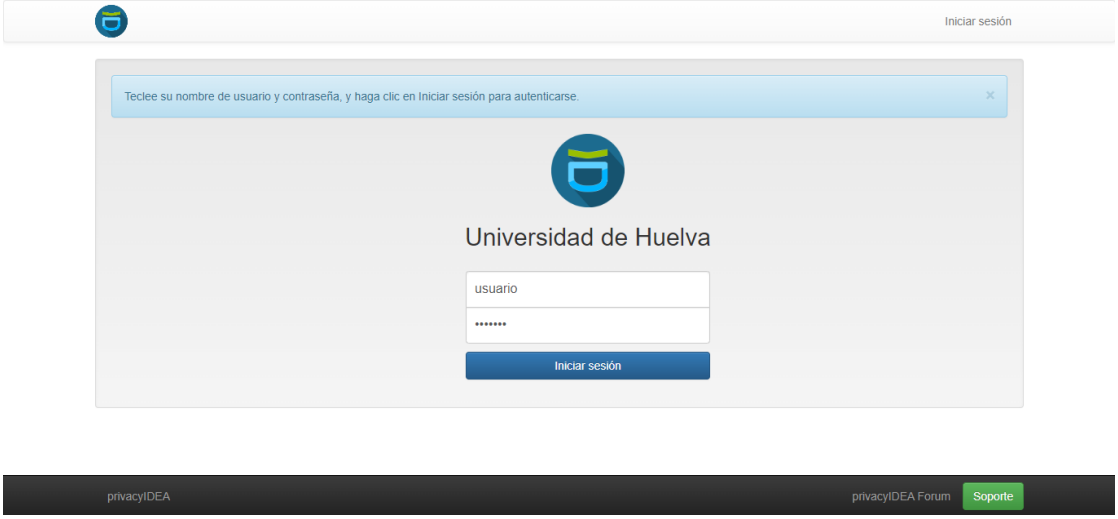

Figura 6.5: PrivacyIDEA

4.- Visualizar los tokens y registrar nuevos tokens:

- Después de autenticarte, verás una lista de los tokens guardados y la opción para registrar nuevos tokens.

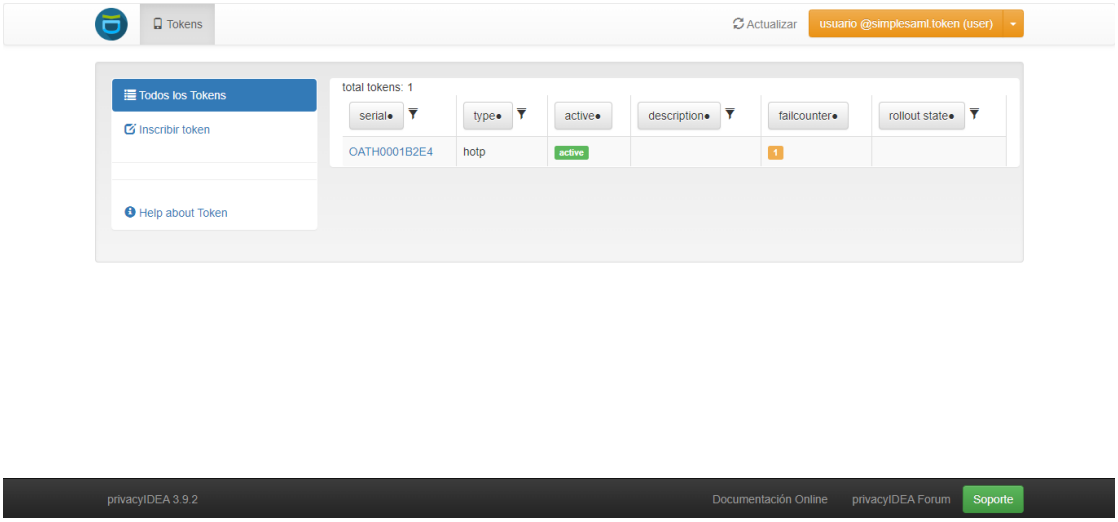

Figura 6.6: Menú PrivacyIDEA

5.- Seleccionar el tipo de token:

- Cuando optes por registrar un nuevo token, se te presentarán diferentes opciones. En tu caso, verás las opciones de HOTP, SPASS, U2F y modo YubiKey AES, esto se debe a que se a configurado en las políticas de usuario.

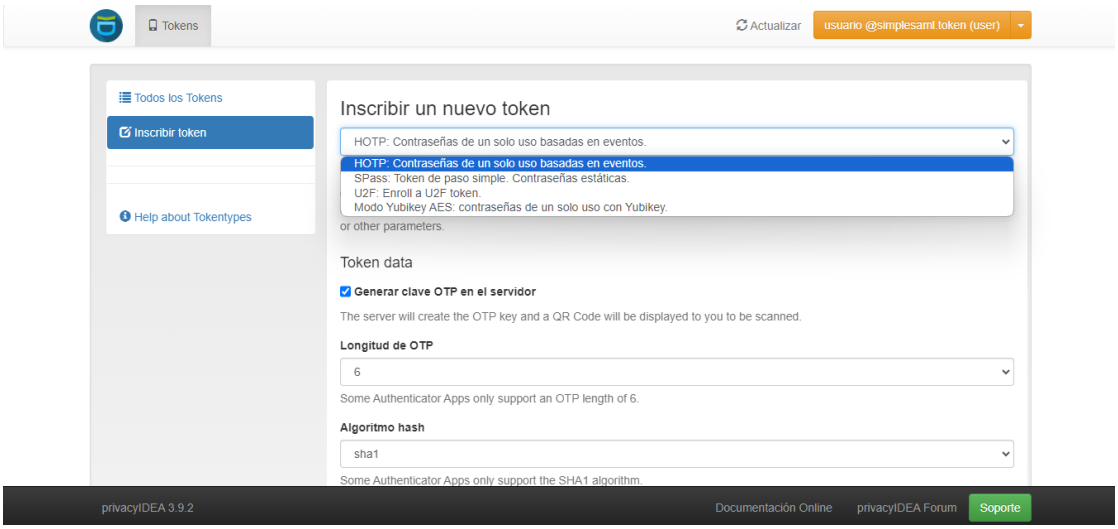

Figura 6.7: Registro de Tokens

6.3.2. Autenticación Sin Segundo Factor

1.- Elegir el servicio de autenticación:

- Accede a la opción "Test authentication sources".
- Selecciona el servicio configurado con autenticación en el proveedor de identidad (IdP).

2.- Redirección al primer factor de autenticación del IdP:

- Después de seleccionar el servicio, serás redirigido al primer factor de autenticación del IdP. Esto incluye la introducción de credenciales como nombre de usuario y contraseña.

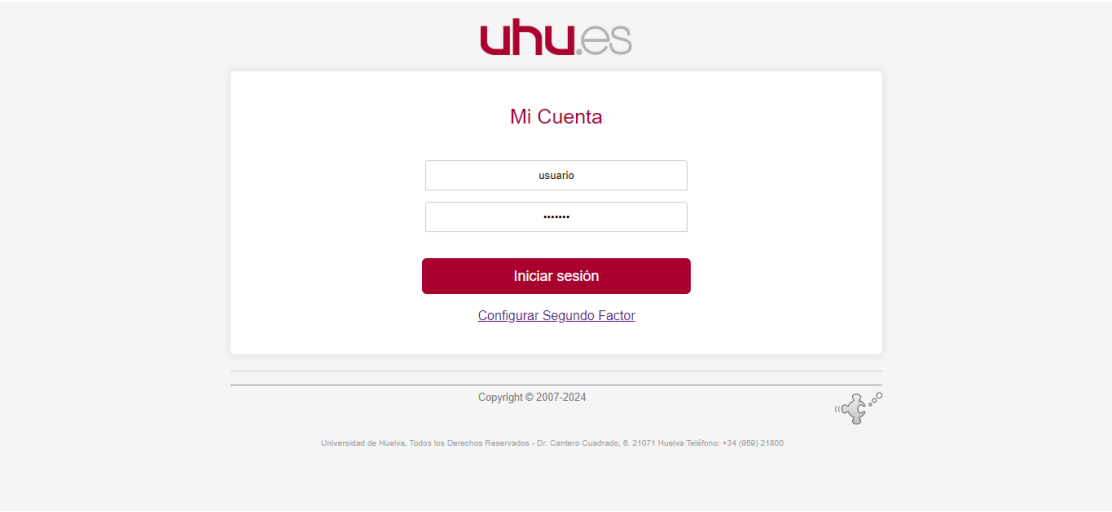

Figura 6.8: Primer Factor

3.- Guardar Cookies:

- Al autenticarse se muestra una página para guardar los datos del usuario

Figura 6.9: Aceptar Cookies

Acceso concedido o denegado:

- Si la autenticación es exitosa, se te concederá acceso al servicio y podrás continuar con tus actividades.
- En este caso como el usuario aun no a configurado ningún segundo factor, le salta una ventana de emergencia

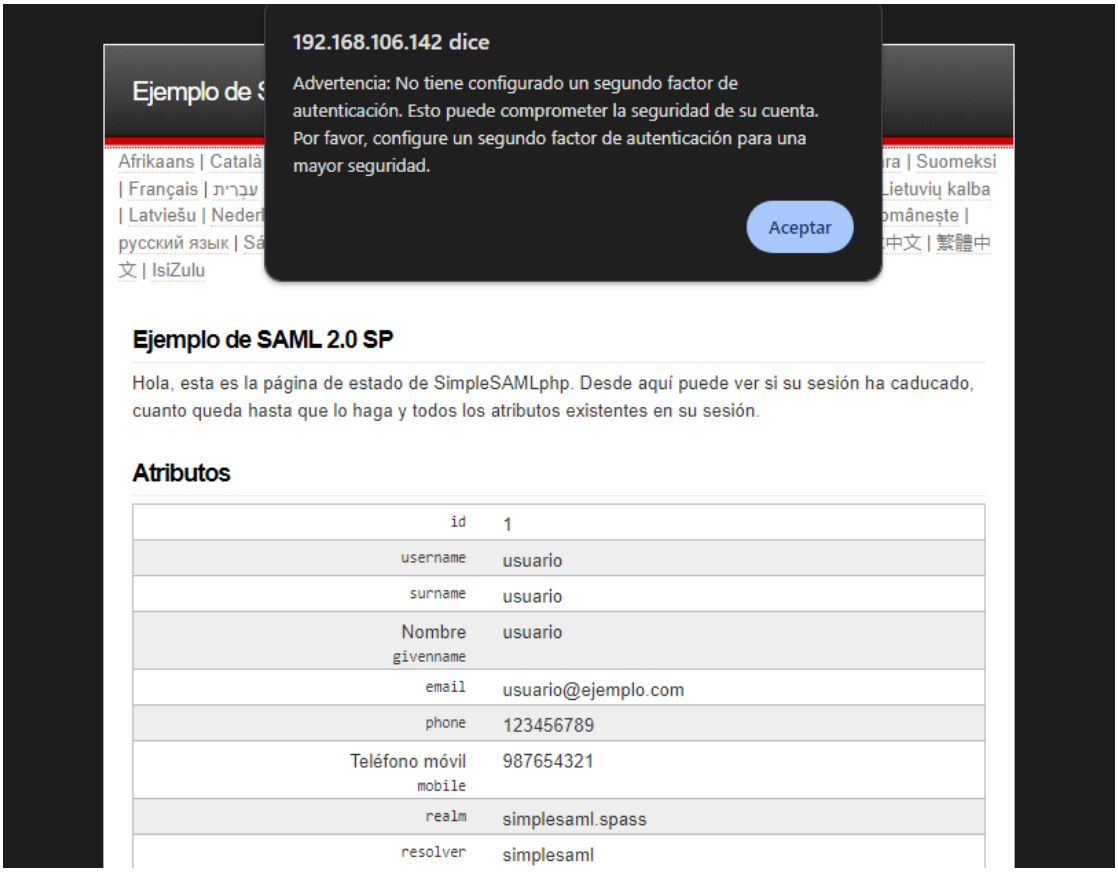

Figura 6.10: Datos del Usuario

6.3.3. Autenticación Con Segundo Factor (HOTP)

Una vez verificado el usuario y la contraseña, se muestra una página para ingresar el segundo factor de autenticación registrado en privacyIDEA.

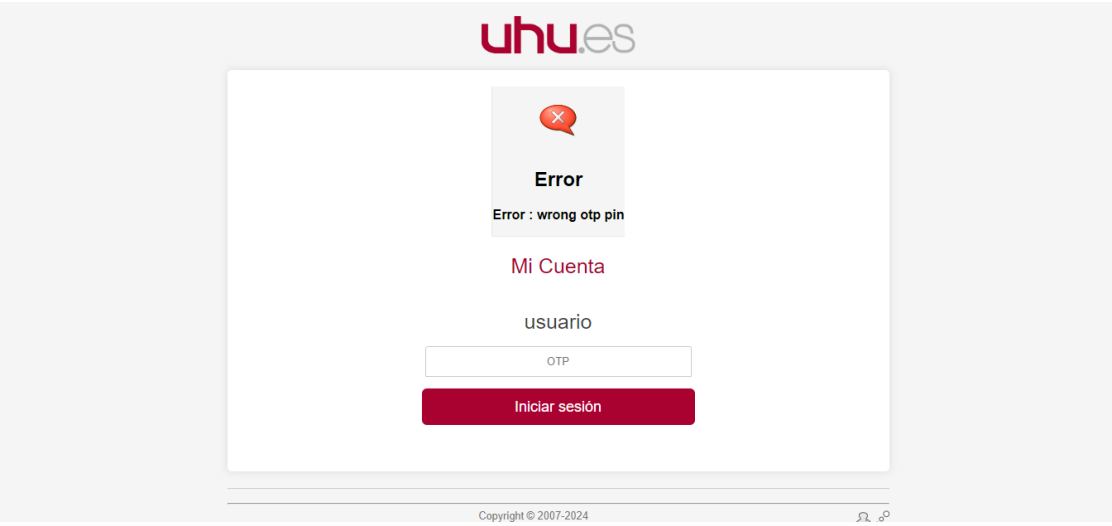

Figura 6.11: Ingresar HOTP

6.3.4. Autenticación Con Segundo Factor (FIDO)

También se puede usar como segundo factor el Yubikey en este caso en la página pone que se debe ingresar el dispositivo y pulsar el botón.
También se puede poner uno de los factores como predeterminado para la autenticación.

6.4. Comparación con Otros Métodos de Autenticación

6.4.1. Resultados y Análisis Comparativos

En este contexto, es crucial realizar un análisis comparativo exhaustivo para evaluar la eficacia y la idoneidad de cada método en diferentes contextos de uso. En este sentido, se examinarán métodos convencionales como el correo electrónico y los mensajes SMS, así como tecnologías más avanzadas como FIDO U2F, TOTP y HOTP. Este análisis permitirá discernir cuál de estas soluciones proporciona el equilibrio óptimo entre seguridad, usabilidad, implementación, resistencia a ataques y compatibilidad, contribuyendo así a una toma de decisiones fundamentada en la elección del método de autenticación más adecuado para diversas aplicaciones y entornos.

FIDO (U2F y FIDO2):

- Seguridad: Utiliza autenticación basada en clave pública para una seguridad sólida. Las claves privadas nunca abandonan el dispositivo del usuario, lo que reduce el riesgo de compromiso.
- Usabilidad: Ofrece una experiencia de usuario conveniente al eliminar la necesidad de recordar contraseñas complejas y al permitir la autenticación mediante dispositivos biométricos o físicos.

- Implementación: Proporciona un estándar abierto y ampliamente adoptado con múltiples opciones de implementación que ofrecen flexibilidad.
- Resistencia a ataques: Altamente resistente a ataques de phishing y de intermediarios debido a su canal seguro y la ausencia de intercambio de secretos.
- Compatibilidad: Compatible con una amplia gama de dispositivos y navegadores modernos, y es interoperable entre diferentes servicios en línea.

HOTP (HMAC-based One-Time Password):

- Seguridad: Basado en un algoritmo HMAC, que proporciona seguridad contra ataques de reproducción. Sin embargo, puede ser vulnerable a ataques de intermediarios.
- Usabilidad: Requiere que los usuarios ingresen un código generado en un dispositivo, lo que puede ser menos conveniente en comparación con las opciones de autenticación sin fricciones.
- Implementación: Ampliamente compatible y fácil de implementar, pero requiere sincronización entre el servidor y el dispositivo del usuario.
- Resistencia a ataques: Puede ser vulnerable a ataques de intermediarios si el código se intercepta durante la transmisión.
- Compatibilidad: Compatible con una variedad de dispositivos y plataformas, pero menos conveniente que las soluciones basadas en FIDO.

TOTP (Time-based One-Time Password):

- Seguridad: Similar a HOTP pero basado en el tiempo, lo que proporciona códigos de un solo uso que caducan después de un período específico.
- Usabilidad: Requiere que los usuarios ingresen un código generado en un dispositivo, similar a HOTP.
- Implementación: Fácil de implementar y compatible con una amplia gama de dispositivos y plataformas.
- Resistencia a ataques: Al igual que HOTP, puede ser vulnerable a ataques de intermediarios si el código se intercepta durante la transmisión.
- Compatibilidad: Ampliamente compatible, pero también menos conveniente que las soluciones basadas en FIDO.

SMS Token:

- Seguridad: Vulnerable a ataques de interceptación de mensajes y suplantación de identidad.

- Usabilidad: Requiere acceso a un dispositivo móvil y puede ser menos conveniente si el usuario no tiene buena cobertura de red.
- Implementación: Fácil de implementar, pero puede estar sujeto a tarifas de mensajería SMS.
- Resistencia a ataques: Puede ser vulnerable a ataques de intermediarios y de suplantación de identidad si el mensaje se intercepta.
- Compatibilidad: Compatible con la mayoría de los dispositivos móviles, pero puede no ser accesible para usuarios que no tienen acceso a un teléfono móvil.

Correo Electrónico:

- Seguridad: El correo electrónico puede ser vulnerable a ataques de phishing y suplantación de identidad si los correos electrónicos son interceptados o si el servidor de correo electrónico es comprometido.
- Usabilidad: Requiere que los usuarios accedan a su bandeja de entrada de correo electrónico para recibir el código de verificación, lo que puede ser conveniente pero también puede generar demoras si hay problemas de entrega.
- Implementación: Fácil de implementar y ampliamente utilizado, ya que la mayoría de las personas tienen acceso a una dirección de correo electrónico.
- Resistencia a ataques: Puede ser vulnerable a ataques de phishing si los usuarios no verifican cuidadosamente la autenticidad del correo electrónico recibido.
- Compatibilidad: Compatible con la mayoría de los dispositivos y plataformas que pueden acceder al correo electrónico, pero puede ser menos conveniente para usuarios que no tienen acceso regular a Internet o que no utilizan correo electrónico con frecuencia.

6.4.2. Ventajas y Desventajas de la Solución Implementada

En este estudio, exploraremos en detalle las ventajas y desventajas de la implementación de FIDO como solución de autenticación para la Universidad de Huelva, comparándola con otros métodos de autenticación tradicionales como contraseñas, SMS y correos electrónicos. Analizaremos la seguridad, la usabilidad, la resistencia a ataques y la compatibilidad de cada enfoque, con el objetivo de proporcionar una evaluación completa y fundamentada de las diferentes opciones disponibles. Mediante esta comparativa exhaustiva, buscamos identificar la solución más adecuada para garantizar la seguridad y la comodidad de la comunidad universitaria de Huelva en su experiencia en línea.

- Seguridad Avanzada: FIDO utiliza un enfoque de autenticación sin contraseña basado en la criptografía de clave pública, lo que elimina las vulnerabilidades asociadas con las contraseñas tradicionales. Al eliminar la necesidad de contraseñas almacenadas centralmente, se reduce significativamente el riesgo de robo de credenciales y ataques de

fuerza bruta.
La autenticación FIDO utiliza factores de autenticación más fuertes, como biometría o dispositivos de seguridad física, que son más difíciles de replicar o comprometer en comparación con las contraseñas estáticas o códigos de un solo uso enviados por SMS o correo electrónico.

- Resistencia a Ataques: FIDO es resistente a una amplia gama de ataques, incluidos el phishing, el robo de contraseñas y los ataques de intermediarios. Dado que la autenticación FIDO se basa en desafíos criptográficos y verificaciones de firma digital, es extremadamente difícil para los atacantes interceptar o falsificar las credenciales de los usuarios.
  La autenticación basada en FIDO también ofrece protección contra ataques de reproducción, ya que cada autenticación genera un token único que no se puede reutilizar en otro contexto.

- Usabilidad Mejorada: FIDO ofrece una experiencia de usuario más fluida y conveniente al eliminar la necesidad de recordar y gestionar contraseñas complejas. Los usuarios pueden autenticarse de forma rápida y sencilla utilizando métodos biométricos como huellas dactilares o reconocimiento facial, o dispositivos de seguridad física como llaves USB.
  Al reducir la fricción en el proceso de inicio de sesión, FIDO mejora la usabilidad y la satisfacción del usuario, lo que puede aumentar la adopción y la aceptación de la tecnología.

- Privacidad y Protección de Datos: FIDO aborda las preocupaciones sobre la privacidad y la protección de datos al minimizar la cantidad de información personal que se comparte durante el proceso de autenticación. Al utilizar métodos de autenticación basados en la verificación local y la firma digital, FIDO protege la privacidad del usuario al tiempo que garantiza la seguridad de la autenticación.
  Además, los datos biométricos utilizados en la autenticación FIDO generalmente se almacenan y procesan localmente en el dispositivo del usuario, lo que reduce el riesgo de exposición a ataques o violaciones de datos.

- Escalabilidad y Flexibilidad: FIDO es altamente escalable y se puede implementar en una variedad de entornos y dispositivos, desde computadoras de escritorio y dispositivos móviles hasta aplicaciones web y servicios en la nube. Esto proporciona flexibilidad para adaptarse a las necesidades cambiantes de la organización y los usuarios.
  Además, FIDO es compatible con una amplia gama de proveedores y servicios, lo que garantiza la interoperabilidad y la capacidad de integración con sistemas existentes sin necesidad de realizar cambios significativos en la infraestructura de autenticación.

Capítulo 7

Resultados y Conclusiones

7.1. Análisis de Resultados

En este estudio comparativo de métodos de autenticación en línea, se han evaluado diferentes enfoques, desde las contraseñas tradicionales hasta la tecnología FIDO, con el objetivo de identificar las soluciones más efectivas y seguras para la Universidad de Huelva. A continuación, se presenta un análisis detallado de los resultados obtenidos:

Seguridad:

- Las contraseñas tradicionales son susceptibles a ataques de fuerza bruta, robo o ingeniería social, lo que las hace vulnerables a la suplantación de identidad.
- Los métodos basados en SMS y correo electrónico también presentan riesgos de seguridad, ya que los mensajes pueden ser interceptados o el dispositivo móvil o la cuenta de correo pueden ser comprometidos.
- En contraste, la tecnología FIDO ofrece un alto nivel de seguridad mediante el uso de autenticación multifactorial basada en criptografía de clave pública. Esto reduce significativamente el riesgo de ataques de suplantación de identidad y phishing, ya que elimina la necesidad de contraseñas y utiliza métodos de autenticación más sólidos, como la biometría o dispositivos de seguridad física.

Usabilidad:

- Las contraseñas son propensas a olvidos y pueden resultar en una experiencia de usuario frustrante, especialmente con la proliferación de servicios en línea que requieren credenciales únicas.
- Los métodos de autenticación basados en SMS y correo electrónico pueden ser inconvenientes para los usuarios, ya que dependen de la disponibilidad de señal móvil o acceso a la bandeja de entrada.

- FIDO ofrece una experiencia de usuario simplificada al eliminar la necesidad de recordar contraseñas complejas o esperar la recepción de códigos de un solo uso. La autenticación se realiza de forma rápida y transparente, generalmente con un simple toque o escaneo biométrico.

Implementación:

- La implementación de contraseñas tradicionales puede requerir una gestión compleja de políticas de contraseñas y medidas adicionales de seguridad, como la autenticación multifactorial.
- Los métodos basados en SMS y correo electrónico también pueden implicar costos adicionales asociados con el envío de mensajes o la integración con proveedores de servicios de comunicación.
- FIDO, aunque requiere la adquisición de dispositivos compatibles, ofrece una implementación relativamente sencilla y escalable, con una amplia gama de opciones disponibles en el mercado y soporte para estándares abiertos.

Resistencia a ataques:

- Las contraseñas son vulnerables a una variedad de ataques, incluidos los de fuerza bruta, diccionario y de ingeniería social.
- Los métodos basados en SMS y correo electrónico pueden ser comprometidos mediante técnicas de suplantación de identidad o interceptación de mensajes.
- FIDO proporciona una mayor resistencia a los ataques mediante la utilización de protocolos criptográficos robustos y métodos de autenticación más seguros, lo que hace que sea más difícil para los adversarios comprometer las credenciales de los usuarios.

Compatibilidad:

- Las contraseñas son ampliamente compatibles con una variedad de sistemas y aplicaciones, pero su eficacia en la protección de la seguridad está cada vez más cuestionada.
- Los métodos basados en SMS y correo electrónico también son compatibles con muchas plataformas, pero pueden presentar problemas de interoperabilidad y dependencia de proveedores externos.
- FIDO está ganando rápidamente aceptación y soporte en la industria, con una creciente adopción en sistemas operativos, navegadores y aplicaciones web, lo que garantiza una mayor compatibilidad y una experiencia de usuario uniforme.

En conclusión, el análisis de los resultados destaca las claras ventajas de la tecnología FIDO sobre los métodos tradicionales de autenticación en términos de seguridad, usabilidad, implementación, resistencia a ataques y compatibilidad. FIDO ofrece una solución integral y avanzada que aborda de manera efectiva los desafíos de seguridad en línea, proporcionando una experiencia de autenticación más segura, conveniente y confiable para los usuarios de la Universidad de Huelva y más allá.

Capítulo 8

Adaptación del IDP de la Universidad de Huelva al ENS

En este capítulo, se analiza y compara las distintas opciones disponibles para adaptar el Proveedor de Identidad (IDP) de la Universidad de Huelva al Esquema Nacional de Seguridad (ENS). La finalidad es desplegar una solución que garantice la conformidad con los requisitos legales y normativos establecidos[32].

8.1. Opciones de Adaptación del IDP al ENS

Opción 1: Implementación de FIDO:
FIDO cumple con los requisitos de autenticación robusta del ENS al eliminar las contraseñas y utilizar autenticación multifactor (MFA), reduciendo significativamente el riesgo de ataques de phishing y robo de credenciales. Utiliza técnicas de criptografía de clave pública para autenticar a los usuarios de manera más segura y eficiente. Desventajas:

- Requiere dispositivos compatibles con FIDO.
- Puede implicar un costo elevado de implementación inicial.

Opción 2: Implementación de PrivacyIDEA:
PrivacyIDEA cumple con los requisitos del ENS ofreciendo una gestión centralizada de la autenticación, soporte para múltiples métodos de MFA, y capacidades de auditoría y trazabilidad. Desventajas:

- Requiere integración con los sistemas existentes.
- Posible complejidad en la configuración inicial.

Opción 3: Integración con SimpleSAMLphp:
SimpleSAMLphp puede cumplir con los requisitos del ENS, especialmente cuando se utiliza junto con otros mecanismos de autenticación robusta y de gestión de accesos. Actúa como middleware en la autenticación y autorización de usuarios. Desventaja:

- Requiere configuración detallada y correcta implementación de políticas de seguridad.

8.2. Selección de la Solución y Justificación

PrivacyIDEA ha sido seleccionada como la solución para adaptar el IDP de la Universidad de Huelva al ENS.

PrivacyIDEA ofrece una solución equilibrada que cumple con los requisitos de autenticación robusta, gestión de accesos, y auditoría y trazabilidad del ENS. Su flexibilidad, soporte para múltiples métodos de autenticación y gestión centralizada de tokens la convierten en una opción robusta y escalable. Además, aunque tiene una complejidad inicial de configuración, su mantenimiento y actualización son manejables y cuentan con un buen soporte técnico.

Capítulo 9

Glosario

- Afirmación de Autenticación: Se refiere al objeto firmado con las claves asimétricas recibido por el autenticador, típicamente después del envío de un desafío que verifica su identidad.
- Agente de Usuario: Es la entidad que implementa la API de WebAuthn, como un navegador web, y maneja la comunicación entre el servidor y el autenticador.
- Atestación (Attestation): La atestación en el contexto de WebAuthn se refiere al proceso u objeto que verifica la procedencia de un autenticador y los datos que emite, como el AAGUID, las claves del fabricante, el par de claves del usuario, etc. Esto permite al servidor evaluar el nivel de confianza que debe tener en dicho autenticador, y se realiza durante la etapa de registro.
- Autenticación: Es el proceso mediante el cual se verifica que algo o alguien es quien dice ser, confirmando su identidad.
- Autenticación en Dos Factores (A2F): Es un método de autenticación que utiliza dos componentes diferentes para verificar la identidad de un usuario, como por ejemplo algo que sabe (contraseña) y algo que posee (token físico).
- Autenticación Multifactor (MFA): Aunque WebAuthn se centra en la autenticación sin contraseña, es posible combinarlo con otros factores de autenticación, como un PIN o una autenticación biométrica, para proporcionar una autenticación multifactor más robusta.
- Autenticador: Es un dispositivo o entidad criptográfica con el cual el usuario se comunica a través del agente de usuario, y en el cual se generan credenciales de clave pública que posteriormente pueden ser utilizadas para autenticar al usuario frente a una plataforma.
- Autenticador Biométrico: Es cualquier dispositivo de autenticación que incorpora métodos de verificación biométrica, como la huella dactilar.

- Certificado de Atestación (Attestation Certificate): Es un certificado X.509 mediante el cual el autenticador intenta certificar su fabricación y capacidades. Cuando se genera un nuevo par de credenciales, el autenticador lo firma con su clave privada de certificación, lo que permite su posterior verificación en el lado del servidor.

- Cliente WebAuthn: Es la entidad intermediaria, alojada en el agente de usuario, que implementa la API de WebAuthn y gestiona la comunicación entre el servidor y el autenticador.

- Clave Pública del Usuario: Es el par de claves generado por el autenticador. La parte pública de estas claves se transfiere al servidor durante el proceso de registro, mientras que la parte privada se utiliza durante la autenticación.

- Credencial: Es un documento o información que autoriza la identidad de un individuo ante una entidad. En el contexto de WebAuthn, se refiere a las claves utilizadas por el usuario para autenticarse ante un servicio.

- Credencial Residente: Consiste en un par de claves almacenadas en un autenticador con la propiedad de clave residente, lo que permite al usuario seleccionar la credencial con la que desea autenticarse durante el proceso de autenticación.

- Criptografía Asimétrica: También conocida como criptografía de clave pública, es un método criptográfico que utiliza dos claves complementarias (pública y privada) para cifrar y descifrar información, así como para firmar y verificar la integridad de los datos.

- CTAP y CTAP2: CTAP (Conjunto de Protocolos de Autenticación) es un conjunto de protocolos para comunicarse desde el cliente con el autenticador a través de diferentes medios de transporte. CTAP2 es la segunda versión del protocolo CTAP, que utiliza CBOR para la codificación y tiene compatibilidad hacia atrás con CTAP1 (U2F), además de extensiones y nuevos formatos de certificación.

- Desafío (Challenge): Es un valor aleatorio generado por el servidor durante el proceso de autenticación y enviado al cliente para que sea firmado por el autenticador. Este desafío ayuda a evitar ataques de repetición y a garantizar que la autenticación sea en tiempo real.

- Estándar: Un conjunto de reglas y directrices definidas por consenso y aprobadas por una entidad reconocida, que proporciona una forma común de uso repetido.

- Fuente de Credenciales de Clave Pública: Se refiere a la información de la credencial almacenada en el autenticador y utilizada para generar afirmaciones de autenticación.

- Gesto de Autorización: Durante la comunicación entre el cliente y el autenticador, puede ser necesario verificar la presencia del usuario mediante algún gesto, como la pulsación de un botón, como forma de consentimiento.

- ID de Credencial: Es una cadena de bytes que identifica de manera única un par de claves. Se genera durante la creación de nuevas claves (registro) y se almacena comúnmente en el servidor para solicitar una afirmación posterior.
- Identificador de la Parte que Confía (ID RP): Es una cadena de texto (por ejemplo, login.example.com) que referencia al servidor y se asocia con cada par de claves. Esto asegura que solo el origen pueda utilizar las credenciales asociadas con el mismo ID RP, y la comunicación debe realizarse a través de un canal seguro (HTTPS).
- Identificador de Usuario (User Handle): Es una cadena adjunta a la información de una credencial y especificada por el servidor, cuyo valor referencia la cuenta del usuario.
- JavaScript: Es un lenguaje de programación interpretado comúnmente utilizado en el lado del cliente para mejorar la interactividad y la apariencia de las páginas web.
- Lado del Cliente: Es el conjunto de la plataforma del cliente, el usuario y el autenticador utilizado durante los procesos de comunicación.
- Límite de Tasa: Es un método utilizado por los autenticadores para controlar los ataques de fuerza bruta. Limitan el número de intentos fallidos consecutivos, aplicando un retraso cuando sea necesario para prevenir posibles ataques.
- MySQL: Es un sistema de gestión de bases de datos relacionales de código abierto ampliamente utilizado en aplicaciones y servicios web, utilizado para almacenar información de usuarios en el contexto de WebAuthn.
- Niveles de Atestación: Los autenticadores pueden ofrecer diferentes niveles de atestación que afectan la confianza que se deposita en ellos. Estos niveles pueden incluir atestaciones básicas, auto-atestación, o atestaciones respaldadas por una autoridad de certificación.
- OpenSSL: Es un proyecto de software libre que proporciona una colección de herramientas y bibliotecas relacionadas con la criptografía. Se utiliza en el contexto de WebAuthn para verificar firmas durante los procesos de registro y autenticación.
- Plataforma Cliente: Es la combinación de un dispositivo junto con la implementación del estándar (API), formando la plataforma cliente.
- Servidor Web: Es un programa informático del lado del servidor que acepta y procesa solicitudes HTTP de los clientes, enviando respuestas adecuadas.
- Tercera Parte que Confía (WebAuthn Relying Party): Es la plataforma, como una aplicación web, que utiliza la API de WebAuthn para autenticar a sus usuarios.
- Token Físico de Seguridad: Es un dispositivo electrónico utilizado por el usuario para facilitar el proceso de autenticación en un servicio, generando y almacenando claves asimétricas.

Bibliografía

Juan Jesús Velasco. *Breve historia de la criptografía*. El Diario, 20 de mayo de 2014. https://www.eldiario.es/turing/criptografia/breve-historia-criptografia_1_4878763.html. Accessed 23 May 2024.

Wikipedia. *Historical Timeline of Biometric Authentication*. https://clockit.io/es/historical-timeline-biometric-authentication/. Accessed 23 May 2024.

Wikipedia. *Título del artículo de HID Global*. https://blog.hidglobal.com/node/39116. Accessed 23 May 2024.

Wikipedia. *Historia de la autenticación multifactor: Orígenes y evolución de un método crucial*. https://cyberprotegidos.info/historia-de-la-ciberseguridad/historia-autenticacion-multifactor-origenes-evolucion-metodo-crucial/. Accessed 23 May 2024.

La evolución de los métodos de autenticación. https://fastercapital.com/es/tema/la-evoluci%C3%B3n-de-los-m%C3%A9todos-de-autenticaci%C3%B3n.html. Accessed 23 May 2024.

Sébastien Viou. *Fallos y vulnerabilidades de la autenticación de dos factores*. Stormshield, 3 de mayo de 2023. https://www.stormshield.com/es/noticias/autenticacion-de-dos-factores-los-rumores-sobre-su-muerte-son-prematuros/. Accessed 24 May 2024.

Cinco Días. *Fallos y vulnerabilidades de la autenticación de dos factores.*. 22 de Enero de 2010. Recuperado de https://cincodias.elpais.com/cincodias/2010/01/22/empresas/1264171213_850215.html#

Xataka Móvil. *FIDO2, así es el estándar que quiere que te olvides de las contraseñas en el móvil.*. 5 de Marzo de 2019. Recuperado de https://www.xatakamovil.com/desarrollo/fido2-asi-estandar-que-quiere-que-te-olvides-contrasenas-movil

Advanced Protection Program. *FIDO2, así es el estándar que quiere que te olvides de las contraseñas en el móvil.*. Recuperado de https://landing.google.com/advancedprotection/

Statistics Sources. *FIDO2, así es el estándar que quiere que te olvides de las contraseñas en el móvil.*. 18 de diciembre de 2023. Recuperado de https://fidoalliance.org/statistics-sources/

Yubico. *Yubico and Google collaborate on U2F*. 2017. Recuperado de https://www.yubico.com/2017/10/yubico-google-u2f/

FIDO Alliance. *FIDO2: Moving the World Beyond Passwords*. S.f. Recuperado de https://fidoalliance.org/fido2/

Whitebear Solutions. *¿Cómo solucionar los errores de autenticación en el acceso a tus sistemas empresariales?*. 20 de febrero de 2023. Recuperado de https://whitebearsolutions.grupocibernos.com/blog/solucionar-errores-de-autenticacion. Accessed 24 de mayo de 2024.

IT Digital Security. *Errores y riesgos asociados a la creación de contraseñas*. 2 de mayo de 2024. Recuperado de https://www.itdigitalsecurity.es/actualidad/2024/05/errores-y-riesgos-asociados-a-la-creacion-de-contrasenas. Accessed 24 de mayo de 2024.

Agencia Española de Protección de Datos. *Notificación de brechas de datos personales a la Autoridad de Control | AEPD*. 29 de abril de 2024. Recuperado de https://www.aepd.es/derechos-y-deberes/cumple-tus-deberes/medidas-de-cumplimiento/brechas-de-datos-personales-notificacion. Accessed 24 de mayo de 2024.

Wikipedia. *WebAuthn*. Recuperado de https://es.wikipedia.org/wiki/WebAuthn. Accessed 24 de mayo de 2024.

Wikipedia. *Client to Authenticator Protocol*. Recuperado de https://en.wikipedia.org/wiki/Client_to_Authenticator_Protocol. Accessed 24 de mayo de 2024.

Campillo, Rafael. *¿Qué es FIDO2? Para qué sirve y cómo funciona*. Mobbeel. Recuperado de https://www.mobbeel.com/blog/que-es-fido2-para-que-sirve-y-como-funciona/. Accessed 24 de mayo de 2024.

Trevino, Aranza. *¿Qué es la criptografía de curva elíptica?*. Keeper Security. 7 de junio de 2023. Recuperado de https://www.keepersecurity.com/blog/es/2023/06/07/what-is-elliptic-curve-cryptography/. Accedido el 24 de mayo de 2024.

Rico Schmidt, Ernesto. *hmac — Firma y verificación criptográfica de mensajes — El módulo Python 3 de la semana*. Recuperado de https://rico-schmidt.name/pymotw-3/hmac/index.html. Accedido el 24 de mayo de 2024.

Wikipedia. *HMAC*. Recuperado de https://es.wikipedia.org/wiki/HMAC. Accedido el 24 de mayo de 2024.

Yubico. *Yubiko Security Key*. 2024. Consultado el 13 de mayo de 2024. https://www.yubico.com/product/security-key-by-yubico/

Wikipedia. *FIDO2 Explained*. Recuperado de https://hideez.com/en-es/blogs/news/fido2-explained. Accedido el 24 de mayo de 2024.

Hipertextual, *WebAuthn obtiene la luz verde del W3C: las contraseñas de texto se aproximan a su fin*, Hipertextual, marzo 2019. Consultado en mayo 13, 2024. Disponible en: https://hipertextual.com/2019/03/webauthn-es-aprobadoque-dejes-usar-contrasenas-mejore-tu-seguridad

World Wide Web Consortium (W3C), *Web Authentication: An API for accessing Public Key Credentials*, W3C Recommendation, 2019. Consultado en mayo 13, 2024. Disponible en: https://www.w3.org/TR/webauthn/

Internet Assigned Numbers Authority (IANA), *CBOR Object Signing and Encryption (COSE)*, IANA. Consultado en mayo 13, 2024. Disponible en: https://www.iana.org/assignments/cose/cose.xhtmittalgorithms

FIDO Alliance, *Client to Authenticator Protocol (CTAP)*, FIDO Alliance Specifications, 2019. Consultado en mayo 13, 2024. Disponible en: https://fidoalliance.org/specs/fidov2.0-ps-20190130/fido-client-to-authenticator-protocol-v2.0-ps-20190130.html

Qherriemand, *Introduction to WebAuthn API*, Medium, 2024. Consultado en mayo 13, 2024. Disponible en: https://medium.com/Qherriemand/introduction-to-webauthn-api-5fd1fb46c285

"Web Authentication: An API for accessing Public Key Credentials - Level 2," *W3C*, 8 de abril de 2021, https://www.w3.org/TR/webauthn/, Consultado en mayo 24, 2024.

"Introduction to WebAuthn API and Passkey | by Ackermann Yuriy | WebAuthn Works," *Medium*, 15 de enero de 2019, https://medium.com/webauthnworks/introduction-to-webauthn-api-5fd1fb46c285, Consultado en mayo 24, 2024.

"Documentation," *SimpleSAMLphp Documentation*, https://simplesamlphp.org/docs/contributed_modules.html, Consultado en mayo 24, 2024.

ENS, *Portal de la Administración Electrónica*, Esquema Nacional de Seguridad, 2019. Consultado en mayo 13, 2024. Disponible en: https://administracionelectronica.gob.es/pae_Home/pae_Estrategias/pae_Seguridad_Inicio/pae_Esquema_Nacional_de_Seguridad.html